

Received 30 August 2026, accepted 17 September 2026, date of publication 21 September 2026,
date of current version 30 September 2026.

Digital Object Identifier 10.1109/ACCESS.2026.3735972

RESEARCH ARTICLE

Bayesian and Multi-Objective Decision Support for Incident Mitigation in Cyber-Physical Systems

SHAOFEI HUANG^{ID}, (Graduate Student Member, IEEE),
CHRISTOPHER M. POSKITT^{ID}, (Member, IEEE), AND LWIN KHIN SHAR^{ID}, (Member, IEEE)

Singapore Management University, Singapore 188065

Corresponding author: Shaofei Huang (sf.huang.2023@smu.edu.sg)

ABSTRACT Cyber-physical systems increasingly rely on interconnected physical and digital systems whose security incidents can escalate rapidly into safety and operational failures. Existing decision-support approaches struggle to support incident response because they rely on static assumptions, incomplete vulnerability data, and single-objective risk models that do not adequately capture trade-offs between attack success likelihood, impact severity, and system availability. This paper proposes an adaptive decision-support framework for incident mitigation in cyber-physical systems that integrates hierarchical Bayesian Network modelling, confidence-calibrated exposure estimation, and multi-objective optimisation into a unified, adaptive pipeline. The framework constructs probabilistic models from system architecture and vulnerability data, incorporating complementary vulnerability scores under epistemic uncertainty as conservative, uncertainty-aware reporting metrics for supporting downstream risk assessment. Mitigation strategies are explored as countermeasure portfolios and refined using multi-objective optimisation to identify Pareto-optimal trade-offs suitable for incident response scenarios. Frequency-based heuristics are applied to prioritise mitigation actions across optimisation runs. The framework is evaluated on three representative cyber-physical attack scenarios, demonstrating its ability to adapt to evolving threats and provide actionable decision support under operational constraints, with the aim of enhancing the resilience of cyber-physical systems.

INDEX TERMS Bayesian networks, cyber-physical systems, decision-support systems, incident response, multi-objective optimisation.

I. INTRODUCTION

Cyber-Physical Systems (CPSs) form the backbone of critical infrastructure, integrating digital and physical components to deliver the essential services that underpin modern society. While traditionally confined to centralised Industrial Control Systems (ICSs), CPSs are now deployed at scale across decentralised infrastructure such as railway signalling networks and renewable energy ecosystems. This expansion has significantly broadened the attack surface for both state-sponsored and opportunistic actors, as digital vulnerabilities now translate directly into physical hazards and operational disruptions that threaten national security and public safety.

The associate editor coordinating the review of this manuscript and approving it for publication was Asad Waqar Malik^{ID}.

A pivotal example of this shifting threat landscape was highlighted in 2025 by Dashevskiy et al. in their SUN:DOWN research report [1], which disclosed 46 new vulnerabilities across leading solar photovoltaic (PV) inverter vendors. These flaws, ranging from insecure cloud APIs to remote code execution, could be chained to orchestrate a coordinated load-changing attack, manipulating inverter output to destabilise grid frequency and potentially triggering large-scale load shedding or emergency equipment shutdowns, underscoring the systemic risk unsecured CPS components pose to infrastructural resilience.

Given the critical nature of these processes, *adaptive* decision support is essential to ensure robust security and incident mitigation, while simultaneously minimising impacts on safety and preserving continuous system availability. In this context, “adaptive” refers to the capacity to

dynamically adjust mitigation strategies based on evolving threat conditions, system states, and resource availability. Unlike traditional IT environments, where remediation typically involves rapid software patching, CPS security decisions must balance cybersecurity objectives against physical process constraints [2]. In legacy CPSs, applying an unvalidated patch entails substantial operational risk. Updates may inadvertently result in latent system failures or performance degradation, necessitating countermeasures that prioritise the resilience of critical infrastructure systems [3].

Despite advancements in model-driven decision support, existing frameworks often operate under static assumptions and lack the adaptability required during an unfolding incident [4], [5]. Most frameworks cannot update model parameters such as vulnerability exposure probabilities or asset interdependencies dynamically. A representative scenario is the detection of a compromised communication dongle mid-response in a power grid. The inability to dynamically revise model attributes constrains operational decision-making and reduces response efficacy in operationally critical contexts.

To address these limitations, we propose an adaptive decision-support framework for incident mitigation in CPSs, grounded in applied probabilistic reasoning and designed to meet the operational realities of CPS protection. We posit that effective response strategies must be guided by data-driven risk metrics while remaining bounded by stringent operational constraints. As illustrated in Figure 1, our proposed framework integrates Bayesian Network (BN) graphs for CPS representation and risk assessment [6], with multi-objective optimisation frameworks to elicit Pareto-optimal countermeasures for incident response [4], [7].

Novelty. The key novelty of this work lies in the integration of confidence-calibrated exposure estimation, BN-based risk propagation, and multi-objective optimisation into a unified, adaptive decision-support pipeline, further augmented by frequency-based heuristics for countermeasure prioritisation. This pipeline renders the Bayesian structures established by Poolsappasit et al. [6], alongside the multi-objective optimisation frameworks proposed by Li et al. [4] and Żebrowski et al. [7], actionable under real-world incident response constraints. Whilst these prior works largely assume well-specified probabilities and static or offline decision contexts, our approach explicitly incorporates *epistemic uncertainty* and *model confidence* into the exposure computation itself, bounding the influence of unreliable proxy scores and producing uncertainty-aware reporting metrics that support downstream risk assessment.

To the authors' knowledge, while commercial platforms such as Dragos and Claroty use machine-learning-based exploitability scoring and expert-driven risk models, they do not explicitly formalise epistemic uncertainty within their exposure metrics [8], [9]. In contrast, our proposed confidence-calibrated metrics provide practitioners with a supporting component to inform risk assessments, whilst its formal integration into the decision-support pipeline remains a direction for future work.

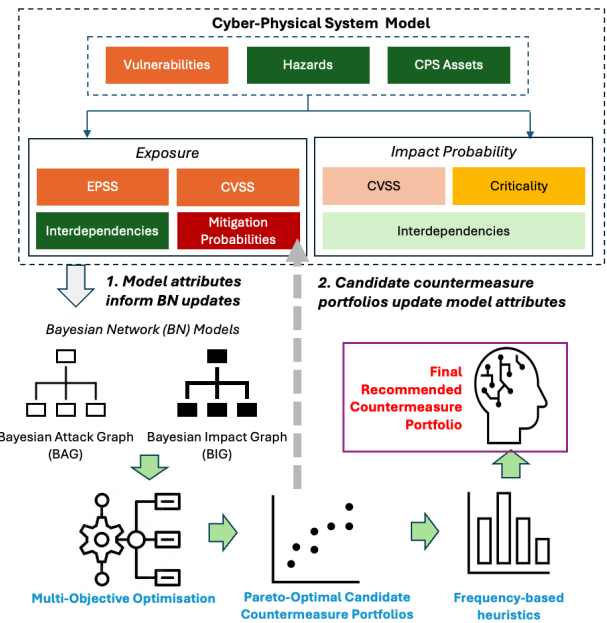


FIGURE 1. Architecture of our proposed CPS security framework. The diagram shows an iterative process integrating a CPS model (vulnerabilities, hazards, assets, exposure/impact probability attributes) with BN graph construction (BAG and BIG). Multi-objective optimisation generates Pareto-optimal countermeasure portfolios, updating model attributes and propagating exposure/impact probabilities. Frequency heuristic analysis selects the optimal portfolio.

Contributions. The main contributions of our paper are summarised below:

- We present a BN-based modelling approach designed explicitly for adaptive incident response in CPSs, rather than offline risk analysis. The model embeds system and vulnerability metadata in a Domain-Specific Language (DSL) [10], enabling rapid updates to structure and parameters as incidents unfold.
- We develop a hybrid exposure probability estimation framework that integrates complementary vulnerability scores through a Bayesian confidence calibration technique. The framework bounds the influence of unreliable proxy scores and produces uncertainty-aware reporting metrics that support downstream risk assessment.
- We introduce a multi-objective decision-support methodology for incident mitigation in cyber-physical systems that balances security, safety, and operational resilience. By treating mitigation probabilities as dynamic decision variables, the framework identifies Pareto-optimal *countermeasure portfolios* tailored to CPS constraints, and uses frequency-based heuristics to prioritise mitigation strategies under operational conditions.
- We demonstrate the applicability of our proposed framework through three representative case studies across diverse CPS domains: the 2015 Ukrainian power grid (BlackEnergy) attack, a solar PV inverter system, and a railway CBTC (Communications-Based Train Control) network.

- The models and source code developed in this research, along with the reference data and formulae used in the framework, are publicly available via the project's GitHub repository [11]. This supports transparency, facilitates reproducibility and enables further development by both the research and practitioner communities within the CPS protection domain.

The remainder of this paper is structured as follows. Section II provides background on the key techniques adopted in this work. Section III explains the proposed methodology. Section IV presents applications of the method to CPS attack scenarios, accompanied by an analysis of experimental results. Section V provides an in-depth, technical discussion of the findings and outlines directions for future research. Section VI reviews related research and identifies limitations in existing approaches. Section VII summarises the key contributions of the study.

II. BACKGROUND

This section outlines the foundational techniques that underpin our proposed framework.

A. BAYESIAN NETWORK GRAPHS

BN graphs are probabilistic graphical models that represent dependencies among variables using directed acyclic graphs, as illustrated in Figure 2. In cybersecurity, BN graphs are widely used to model attack propagation and risk inference [12], and also to support decision-making [13]. Specific to CPS, the works by Bhosale et al. [14], [15] discuss the adaptation of BN graphs to model probabilistic interdependencies between node types associated with CPS, namely, vulnerability nodes, which represent exploitable weaknesses in systems; asset nodes, which denote critical components within the CPS; and hazard nodes, which correspond to severe adverse outcomes including system failures or performance degradation.

Each node is associated with *exposure* and *impact* attributes that quantify the likelihoods of exploitation, failure dependencies, and cascading risks. These attributes shape the propagation of vulnerabilities and attack vectors, influencing the probabilities of attack success and of severe impact to the CPS. Our work builds on these foundations by integrating such BN-based exposure and impact modelling into an adaptive decision-support pipeline for incident mitigation, and by coupling the BN graph with optimisation and heuristic prioritisation to drive operational countermeasure selection rather than using the BN graph solely for static risk analysis.

B. DOMAIN SPECIFIC LANGUAGES

DSLs are concise, processable languages for describing a specific concern when building a system in a specific domain, where the abstractions and notations used are tailored to the stakeholders who specify that particular concern [10]. In this work, we employ AutomationML [16] (an XML-based DSL for representing engineering models) as a means of encoding

and representing BN graphs for automated analysis. Using a DSL such as AutomationML allows CPS practitioners and experts to formally specify CPSs in a BN graph structure (nodes, edges, and conditional probability tables) along with vulnerabilities, assets, and countermeasures in a machine-readable format.

C. VULNERABILITY SCORING SYSTEMS

The Common Vulnerability Scoring System (CVSS) provides a standardised framework for assessing the technical severity of vulnerabilities, with version 3.1 defining metrics to quantify exploitability and impact characteristics [17], [18]. However, as a deterministic scoring system, CVSS often fails to account for the inherent uncertainty and temporal dynamics of real-world attacks. The Exploit Prediction Scoring System (EPSS) addresses this limitation by providing probabilistic estimates of exploitation likelihood over the subsequent 30-day window, grounded in empirical indicators such as exploit availability and active exploitation trends [19].

To achieve a more granular assessment, our framework further integrates the *Known Exploited Vulnerabilities* (KEV) catalogue [20], which identifies vulnerabilities confirmed to have been exploited in real-world scenarios, alongside *Likely Exploited Vulnerabilities* (LEV) [21] data, which provides daily probability estimates of observed exploitation activities. Our approach captures a broader spectrum of the threat landscape by incorporating both authoritative records and statistical exploitation estimates.

While these scoring frameworks are well-established within the cybersecurity community, our framework distinguishes itself by integrating them as complementary scoring schemes within a Bayesian calibration mechanism, yielding uncertainty-aware metrics that explicitly account for incomplete or heterogeneous vulnerability metadata and support our decision-support process.

D. MULTI-OBJECTIVE OPTIMISATION

CPS decision makers are often constrained by fixed budgets that fall short of the minimum cost required for comprehensive system hardening. The challenge lies in selecting a subset of security measures that remain within budget while minimising residual risk from unaddressed vulnerabilities [22]. Multi-objective optimisation addresses this challenge by identifying solutions that balance competing objectives, such as cost, system availability, and risk reduction. Prior research has explored Bayesian optimisation and evolutionary strategies to derive optimal security configurations under uncertainty and resource constraints [4], [22]. In particular, the work by Żebrowski et al. [7] formulates the optimisation task as a Pareto-efficient portfolio selection problem, leveraging a Bayesian Network to identify security measures that simultaneously minimise various types of expected cyberattack impacts, while satisfying budgetary and other constraints. Our work extends this approach by treating mitigation probabilities as parameters that shape the decision variables within the optimisation space, repeatedly updating

BN graph parameters in response to candidate portfolios, and applying frequency-based heuristic analysis across multiple optimisation runs to prioritise countermeasures under operationally-constrained incident response conditions.

III. METHODOLOGY

This section describes the methodology of our proposed framework, illustrated with a running example of a solar PV inverter attack, which is based on the security reports by Dashevskiy et al. [1] and Dabrowski et al. [23]. In particular, we refer to their identified CVE (Common Vulnerabilities and Exposures) entries that can be chained to form hypothetical attack paths targeting solar PV inverter systems. While Dabrowski et al. originally proposed destabilising the power grid via coordinated load modulation from a botnet of consumer devices, our scenario explores a complementary threat vector focused on the supply side. Here, the adversary leverages mobile or web applications to obtain sensitive information, which is then used to compromise a message broker and subsequently a controller linked to both the message broker and a solar PV inverter. Once initial access is established, the attacker hijacks additional inverters and synchronises their configuration changes to create abrupt fluctuations in grid input. By overwhelming the grid's balancing mechanisms, this coordinated attack can degrade grid stability or result in power outages, thereby achieving the attacker's ultimate objective.

Overview. Our framework (Figure 1) begins with the construction of a BN graph that defines a shared structure for attack and impact graphs, informed by CPS attributes and the attack scenario. Randomised mitigation probability values are introduced as initial inputs into a multi-objective optimisation process, which generates candidate countermeasure portfolios aimed at maximising system availability while minimising the likelihood of attack success and severe impact occurrence. These portfolios are subsequently reintegrated into the BN graph as updated mitigation probabilities, and the optimisation cycle is repeated across multiple trials within a single run. The top-performing portfolios from these iterative runs are then analysed using frequency-based heuristics to identify vulnerability nodes within the attack path that consistently exhibit high mitigation effectiveness. This insight serves to continually guide and inform final prioritisation decisions during incident response. The high-level steps of our proposed framework are outlined in Algorithm 1. Each step is elaborated in detail in Sections III-A to III-F.

A. BAYESIAN NETWORK MODEL CONSTRUCTION

Extending the work of Żebrowski et al. [7] and Bhosale et al. [14], [15], we construct an abstract BN graph that captures the relevant cyber-physical structure of the target CPS. The construction process follows a systematic procedure:

- **Node identification:** We define three classes of nodes: (i) *asset nodes* representing physical or cyber components (e.g., PLCs, sensors, communication links),

Algorithm 1 Methodology of Proposed CPS Decision Support Framework

```

1: Build BN graph integrating CPS metadata and attack scenario context,
   encoded in AutomationML (§ III-A)
2: Compute exposure probabilities for nodes within the BN graph,
   representing likelihoods of attack success (§ III-B)
3: Calculate propagated impact probabilities resulting from exploitation
   or failure of BN graph nodes (§ III-C)
4: Calculate posterior likelihoods of successful attack and severe impact,
   conditioned on observed evidence within the BN graph (§ III-D)
5: for num_runs = 1 to max_num_runs do
6:   for num_trials = 1 to max_num_trials do
7:     Run multi-objective optimisation to generate candidate coun-
       termeasure portfolios (§ III-E)
8:     Update BN graph mitigation attributes using top-performing
       candidate portfolio
9:   end for
10:  Identify high-impact mitigation nodes for prioritisation under
      operational constraints, by analysing frequency-based heuristics of
      top-performing portfolios (§ III-F)
11: end for
12: Recommend final countermeasure portfolio

```

(ii) *vulnerability nodes* representing exploitable weaknesses associated with assets, and (iii) *hazard nodes* representing unsafe system states or adverse outcomes (e.g., loss of control, physical damage).

- **Dependency identification:** Directed edges are identified based on causal and conditional dependencies derived from system architecture, data or control flow diagrams, and expert knowledge. Specifically, edges are added from assets to their associated vulnerabilities, between vulnerabilities to represent multi-step attacks, and from compromised assets or vulnerabilities to hazards to capture failure propagation pathways.
- **Parametrisation:** Conditional probability tables are assigned to each node using a combination of sources, including historical incident data, vulnerability metrics (e.g., CVSS, EPSS, KEV scores), and expert judgement. When precise data is unavailable, qualitative likelihoods (i.e., “low”, “medium”, “high”) are mapped to quantitative probabilities using predefined scales.
- **Model instantiation:** A generic BN graph structure is instantiated by integrating relevant assets, vulnerabilities, attack paths, and their associated parameters derived in the earlier steps. This step encodes attack entry points, attack paths, and attacker goals.

This BN graph serves as a shared structural backbone for both the *Bayesian Attack Graph (BAG)* and the *Bayesian Impact Graph (BIG)* used in subsequent stages of the framework. While the BAG models the likelihood of attack success based on the attack path connecting the attacker to vulnerabilities, hazards, and asset failures, the BIG models the likelihood of severe impact to the CPS using the same attributes within an identical BN graph. Given the fixed BN graph structure common to both the BAG and BIG, we incorporate scenario-specific assumptions and hypothesised attack paths to populate asset, vulnerability, and hazard nodes, and encode the resulting model in AutomationML to support systematic analysis and downstream optimisation.

1) RUNNING EXAMPLE

Figure 2 shows a BN graph of a solar PV inverter attack scenario. The graph was constructed by mapping system topology and functional interdependencies referenced from the work by Dashevskyi et al. [1]. CPS asset, vulnerability, and hazard nodes are instantiated using information from CVE repositories alongside the attack scenario [23].



FIGURE 2. Bayesian Network graph of a hypothetical cyber-physical attack on solar PV inverters connected to a power grid. A high-resolution version of the graph is available in the project's GitHub repository [11].

B. EXPOSURE CALCULATIONS

This subsection outlines our methodology used to compute probabilities of attack success, which we term as *exposure*, for vulnerability, asset, and hazard nodes within the BN graph.

1) VULNERABILITY NODES

The approach for vulnerability nodes needs to account for both publicly disclosed vulnerabilities with CVE identifiers, and proprietary or undocumented vulnerabilities lacking formal CVE enumeration. To calculate the exposures of CVE-linked vulnerability nodes, we use EPSS, LEV, and KEV metrics in conjunction with the *maximal-envelope approach* introduced by Mell and Spring [21] to select the highest exposure probability among these complementary vulnerability scoring frameworks.

The Likely Exploited Vulnerability (LEV) metric is defined by Mell and Spring as:

$$\text{LEV}(v, d_0, d_n) \geq 1 - \prod_{\forall d_i \in \text{dates}(d_0, d_n, 30)} (1 - \text{epss}(v, d_i) \times \text{weight}(d_i, d_n, 30)) \quad (1)$$

where v is the vulnerability; d_0 is the first date on which an EPSS score is available; d_n is the date on which the calculation is performed (usually the present day); $\text{epss}(v, d)$ is the EPSS score for vulnerability v on date d ; and $\text{weight}(d_i, d_n, w)$ is the number of days between d_i and d_n , limited by the window size w , divided by w .

The probability of exposure for a CVE-linked vulnerability, $P(E)_{\text{vuln, CVE}}$ is defined as:

$$P(E)_{\text{vuln, CVE}} = \max(\text{EPSS}, \text{LEV}, \text{KEV}) \quad (2)$$

where $\text{KEV} \in \{0, 1\}$ acts as a logical ceiling, ensuring that any vulnerability confirmed to have been exploited in real-world scenarios is assigned a maximal exposure probability of 1; otherwise, it is assigned 0. If $\text{KEV} = 1$, $P(E)_{\text{vuln, CVE}}$ becomes 1 regardless of EPSS or LEV, as this is a critical safety-conservative assumption for CPSs.

For proprietary or undocumented vulnerabilities lacking CVE identifiers, EPSS, LEV, and KEV metrics are unavailable for exposure probability calculation. Proxy CVSS scores are therefore derived from the CVSS base metrics, computed as follows:

$$P(E)_{\text{vuln, CVSS}} = AV \times AC \times PR \times UI \quad (3)$$

where AV , AC , PR , and UI represent the Attack Vector, Attack Complexity, Privileges Required, and User Interaction metrics, respectively. Each metric is assigned the corresponding numerical weight per the CVSS v3.1 specification [17]. Note that the CVSS v3.1 specification scales the product of these four metrics by a constant factor (8.22) when computing the exploitability sub-score. We omit this scaling constant deliberately as our purpose here is to treat the product as a pseudo-probability of exploitation, bounded naturally in $[0, 1]$ since each metric weight is itself a probability-like value in that range.

From a CPS practitioner perspective, relying on uncalibrated CVSS scores introduces dangerous metric volatility and downstream risk miscalculations. In particular, CVSS scoring for zero-day or proprietary vulnerabilities is notoriously subjective and prone to initial assessor bias [24]. To address this, we employ a *Bayesian confidence calibration technique* inspired by Küppers et al. [25]. We model the observed proxy CVSS score as a distribution linked to a shared latent variable $P(E)_{\text{vuln}}^*$ with a variance of σ_{CVSS}^2 , representing the unobserved true probability of exposure:

$$P(E)_{\text{vuln, CVSS}} \sim \mathcal{N}(P(E)_{\text{vuln}}^*, \sigma_{\text{CVSS}}^2) \quad (4)$$

Assuming a Gaussian prior as proposed by Knapik et al. [26], where $P(E)_{\text{vuln}}^* \sim \mathcal{N}(\mu_0, \sigma_0^2)$, the Bayesian latent variable formulation for the posterior parameters is thus represented as:

$$\mu_{\text{post}} = \frac{\frac{\mu_0}{\sigma_0^2} + \frac{P(E)_{\text{vuln, CVSS}}}{\sigma_{\text{CVSS}}^2}}{\frac{1}{\sigma_0^2} + \frac{1}{\sigma_{\text{CVSS}}^2}} \quad (5)$$

$$\sigma_{\text{post}}^2 = \left(\frac{1}{\sigma_0^2} + \frac{1}{\sigma_{\text{CVSS}}^2} \right)^{-1} \quad (6)$$

The resulting calibrated exposure probability estimate $P(E)_{\text{vuln}}^* \sim \mathcal{N}(\mu_{\text{post}}, \sigma_{\text{post}}^2)$, serves as a unified, uncertainty-aware metric for supporting downstream risk assessment and mitigation optimisation within the BN graphs. Whilst μ_{post}

provides a calibrated point estimate for supporting downstream risk assessment, σ_{post}^2 serves as a supporting component available to practitioners for assessing the reliability of individual exposure estimates. In the current implementation, σ_{post}^2 is surfaced as an uncertainty metric rather than formally propagated into subsequent stages of the pipeline, an extension identified for future work.

In addition, we incorporate an *Attack Feasibility* (AF) modifier, inspired by the work of Xie et al. [27], to ensure the formulation reflects real-world conditions more accurately. This modifier is applied to the probability calculations for all vulnerability nodes. Specifically, the AF modifier adjusts probability estimations by accounting for the system's security posture, adversary capabilities, and environmental constraints. For instance, systems featuring strong defences and restricted access protocols yield lower AF values, reflecting a reduced likelihood of exploitation. Conversely, an unpatched CPS targeted by a sophisticated adversary results in a higher probability of a successful attack. The final probability of a successful attack for a given vulnerability node, irrespective of whether it has a CVE identifier, is defined as:

$$P(A)_{\text{vuln}} = P(E)_{\text{vuln}} \times \phi \quad (7)$$

where:

- $P(A)_{\text{vuln}}$ represents the probability that an attack of the vulnerability node is successful.
- $P(E)_{\text{vuln}}$ denotes the probability of exposure for the vulnerability.
- ϕ is the attack feasibility (AF) modifier, representing context-specific variables such as system defence posture, adversary capability, and environmental constraints.

As precise empirical data is generally unavailable in CPS contexts, a qualitative-to-quantitative mapping (Table 1) is applied to assign ϕ from a four-band scale corresponding to overall attack feasibility.

TABLE 1. Qualitative-to-quantitative mapping for the AF modifier (ϕ).

Band	ϕ	Criteria
Low	0.25	High exploitation difficulty and/or no demonstrated adversary capability against the target; exploitation requires significant resources, specialised access, or conditions unlikely to be met.
Medium	0.50	Moderate exploitation difficulty; some enabling conditions present (e.g., partial access, known but unpatched weakness) without corroborating evidence of adversary intent or capability.
Moderately high	0.75	Low-to-moderate exploitation difficulty, or credible but unconfirmed indicators of adversary capability/interest in the target.
High	1.00	Low exploitation difficulty combined with demonstrated real-world adversary capability against the target (e.g., confirmed active exploitation).

2) ASSET NODES

For an *asset node*, the probability of exposure corresponds to the probability of asset failure because the node's only failure

event is its own failure, and is calculated using an exponential decay function, which models failure likelihood over time:

$$P(E)_{\text{asset}} = 1 - e^{-\lambda t} \quad (8)$$

where λ represents the failure rate per unit time, determining how frequently the asset is expected to degrade, and t denotes the operational duration, reflecting the asset's time in service.

This formulation is grounded in Markov-based reliability analysis [28], in which asset failures are modelled as a stochastic process, capturing the progressive deterioration of system components over time. Through time-dependent degradation patterns, this approach provides a probabilistic estimation of failure likelihood, supporting predictive maintenance and risk-informed decision-making in CPS environments.

3) HAZARD NODES

Finally, *hazard nodes* represent hazardous events, failures, or disruptions influenced by attack propagation. As such, the occurrence of a hazard is influenced by the cyber-physical dependencies within the system. Specifically, downstream hazard exposure is certain ($P(E) = 1$) once its parent hazard occurs or parent asset fails, as the failure propagates through the attack tree. The probability of exposure for a hazard node is thus defined as:

$$P(E)_{\text{haz}} = \begin{cases} 1, & \text{if parent asset fails or parent hazard occurs} \\ 0, & \text{otherwise} \end{cases} \quad (9)$$

We adopt deterministic hazard propagation as a safety-conservative choice, consistent with the worst-case reasoning underlying the KEV ceiling in Equation 2. In practice, CPS environments often incorporate redundancy, protective relays, automated safety interlocks, and operator intervention, any of which may prevent propagation to a downstream node. However, reliably quantifying the failure probability of these protective mechanisms requires system-specific reliability data that is frequently unavailable or commercially sensitive, particularly for legacy CPS assets. In the absence of such data, assuming certain propagation ($P(E) = 1$) avoids the risk of understating hazard likelihood, which we consider the more operationally cautious failure mode for incident-response decision support. We acknowledge that this assumption will overstate risk in systems with effective protective layers, and we identify that probabilistic hazard propagation, conditioned on protection-system reliability where such data is available, is a natural extension once that data exists.

4) RUNNING EXAMPLE

Continuing our running example of the solar PV inverter (Figure 2), EPSS scores and KEV catalogue entries for CVE-identified vulnerabilities were retrieved from the FIRST EPSS and CISA databases respectively. Correspondingly, their LEV scores were computed per Equation 1 using

EPSS scores over a 30-day window ($w = 30$). For example, in the case of V8 (CVE-2024-50687: iSolarCloud API allows unauthorised access to Sungrow device data and parameters), the corresponding vulnerability metrics are listed in Table 2, yielding an exposure probability of $P(E)_{V8,CVE} = 0.0476$ (Equation 2).

TABLE 2. Vulnerability metrics for CVE-2024-50687 (retrieved 2026-06-18). Despite a high CVSS score (9.1), the LEV-derived exposure probability remains low (0.0476), indicating that although the vulnerability has a high theoretical severity score, it is unlikely to be exploited in real-world scenarios.

Scoring System	Score
CVSS v3.1	9.1
EPSS (Latest Score)	0.0041
LEV	0.0476 (4.76%)
KEV	0 (Not listed in CISA catalogue)
$P(E)_{V8,CVE}$	0.0476

We also applied the AF modifier (Equation 7) with a selected value of $\phi = 0.75$ to reflect the contextual conditions documented by Dashevskyi et al. in their report [1]. Specifically, the system's security posture was assessed as weak. Notably, the WiNet-S communication dongle exposed vulnerabilities that allowed device serial numbers to be harvested, contained hard-coded credentials that could be used to decrypt firmware updates, and accepted unauthenticated MQTT messages. These factors collectively enable remote code execution and persistent device takeover. Whilst the underlying vulnerabilities indicate a low barrier to exploitation, no real-world adversary has been observed exploiting these flaws to destabilise solar power grids, and all affected vendors have since released patches. Consequently, a moderately high AF modifier was adopted, reflecting low exploitation difficulty offset by the absence of demonstrated adversary capability and real-world attack validation.

The resulting probability of a successful attack on the vulnerability node is therefore:

$$P(A)_{V8,CVE} = P(E)_{V8,CVE} \times \phi = 0.0357 \quad (10)$$

In this example, V16 is the only vulnerability node that does not have a CVE identifier, and represents a dynamic load-changing attack on the power grid. For this node, we approximated the CVSS-proxy vector based on information from the literature [23]. The CVSS vector (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:H) characterises a network-accessible attack within the CPS. AV:N indicates remote exploitation over a network; AC:L denotes low complexity requiring no specialised preconditions; PR:N and UI:N show that no privileges or user interaction are needed; S:C reflects changed scope impacting beyond the target system; C:N indicates no confidentiality loss; I:L shows low integrity compromise; while A:H signifies high availability impact. Using Equation 3 with the corresponding CVSS metric values [17], the fallback exposure probability

estimate for V16 is calculated as:

$$P(E)_{V16,CVSS} = 0.85 \times 0.77 \times 0.85 \times 0.85 = 0.4729 \quad (11)$$

Next, we applied our Bayesian confidence calibration technique to evaluate the reliability of the fallback exposure probability estimate $P(E)_{V16,CVSS}$, which is assumed to be low-confidence for illustrative purposes. For the prior distribution, we adopted a toy mean of $\mu_0 = 0.5$, reflecting the assumption that empirically similar vulnerabilities have a mean CVSS score of 0.5, together with a conservative standard deviation of 0.05 (variance $\sigma_0^2 = 0.0025$). Finally, we selected a standard deviation of 0.20 (variance $\sigma_{CVSS}^2 = 0.04$) to reflect the low confidence associated with the CVSS-proxy estimate. Substituting these values into Equations 5 and 6 yields the following:

$$\mu_{\text{post}} = \frac{(0.5/0.0025) + (0.4729/0.04)}{(1/0.0025) + (1/0.04)} \approx \mathbf{0.4984} \quad (12)$$

$$\sigma_{\text{post}}^2 = \left(\frac{1}{0.0025} + \frac{1}{0.04} \right)^{-1} = \mathbf{0.00235} \quad (13)$$

The posterior distribution of the shared latent vulnerability exposure probability $P(E)_{V16,CVSS}^*$ is therefore given by:

$$P(E)_{V16,CVSS}^* \sim \mathcal{N}(0.4984, 0.00235) \quad (14)$$

We performed a sensitivity analysis to evaluate this calibration, varying σ_{CVSS} and observing the resulting shift in the posterior mean μ_{post} (Table 3). Under low-confidence assumptions ($\sigma_{CVSS} \geq 0.20$), μ_{post} shifts by at most 0.30% even as σ_{CVSS} quadruples, confirming that the calibration is insensitive to imprecise uncertainty estimates when the prior is trusted. Under high-confidence assumptions ($\sigma_{CVSS} < 0.20$), the corresponding shift is larger (2.46%), showing that assuming high confidence prematurely risks overstating the reliability of the proxy estimate.

TABLE 3. Sensitivity analysis results (Solar PV inverter), showing the effect of varying the CVSS-proxy standard deviation σ_{CVSS} on the calibrated posterior estimate.

Scenario	μ_0	σ_{CVSS}	σ_{CVSS}^2	μ_{post}	σ_{post}^2	Δ (%)
Solar PV (low conf.)	0.5	0.20	0.04	0.4984	0.00235	Baseline
	0.5	0.40	0.16	0.4996	0.00246	0.24%
	0.5	0.60	0.36	0.4998	0.00248	0.28%
	0.5	0.80	0.64	0.4999	0.00249	0.30%
Solar PV (high conf.)	0.5	0.05	0.0025	0.4865	0.00125	Baseline
	0.5	0.10	0.0100	0.4946	0.00200	1.67%
	0.5	0.15	0.0225	0.4973	0.00225	2.23%
	0.5	0.20	0.0400	0.4984	0.00235	2.46%

Finally, the AF modifier of $\phi = 0.75$ was applied. The resulting probability of a successful attack on the vulnerability node V16 is therefore:

$$P(A)_{V16,CVSS} = P(E)_{V16,CVSS}^* \times \phi = 0.3738 \quad (15)$$

Other than vulnerability nodes, exposure probabilities were also assigned to asset and hazard nodes. For asset nodes, Equation 8 was applied using an operational duration defined

from 1 January 2024 to the current date. Failure rates for individual assets, such as the WiNet-S communication dongle connected to the inverter, were estimated from published literature [14] and the technical specifications of comparable components sourced from publicly available documentation. Exposure probabilities for hazard nodes were subsequently assigned using Equation 9, completing the probabilistic exposure attributes of all node types within the BN graph.

C. IMPACT CALCULATIONS

This subsection outlines our methodology used to compute impact-related attributes within the BN graph: the probability of severe impact for vulnerability nodes, and the structural impact score for asset and hazard nodes.

1) VULNERABILITY NODES

In the case of vulnerability nodes (both CVE- and non-CVE-linked), we use the following formulation, drawing on the corresponding CVSS metric values [17], to compute the probability of severe impact to the CPS:

$$P(\text{Impact})_{\text{vuln}} = 1 - [(1 - C) \cdot (1 - I) \cdot (1 - A)] \quad (16)$$

where:

- $P(\text{Impact})_{\text{vuln}}$ denotes the probability of severe impact associated with the vulnerability node.
- C, I, A represent the confidentiality, integrity, and availability impact metrics, respectively. For vulnerabilities that do not have CVE identifiers, the impact metrics are estimated based on available system context, attack surface semantics, or analogous vulnerabilities with similar functionality.

2) ASSET AND HAZARD NODES

In the case of asset and hazard nodes, we compute a structural impact score that reflects the number of child nodes each individual node directly influences, capturing its potential to propagate disruption or failure through the system [14], [29]. This is formulated as:

$$S(a) = \frac{\text{No. of connected child nodes}}{\text{Total no. of nodes in the BN graph}} \quad (17)$$

In this formulation, the structural impact score lies within the interval $[0, 1]$, and asset or hazard nodes with greater downstream reach are assigned proportionally higher scores. We do not, however, interpret $S(a)$ as a validated severity measure: a relay node with a single downstream hazard link but severe consequence could score lower than a node connected to several low-consequence assets, even though the former carries the greater actual risk. We leave severity-weighted or path-based propagation scoring as a refinement for subsequent work.

3) RUNNING EXAMPLE

In our running example, the impact probabilities of vulnerability nodes were calculated using Equation 16, drawing on the confidentiality, integrity, and availability metric values

derived from their respective CVSS vectors. For instance, the vulnerability node $v8$ (CVE-2024-50687) has a CVSS vector: $CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N$. Here, C:H indicates high confidentiality loss (metric value: 0.56); I:H shows high integrity compromise (metric value: 0.56); and A:N signifies no availability impact (metric value: 0). Accordingly, the impact probability for $v8$ was calculated as follows:

$$P(\text{Impact})_{v8} = 1 - [(1 - 0.56) \times (1 - 0.56) \times (1 - 0)] = 0.8064 \quad (18)$$

Within the solar PV inverter BN graph presented in Figure 2, which comprises 30 nodes in total (i.e., excluding the Attacker (AF) node), the impact probabilities of hazard and asset nodes were derived from the underlying interdependencies among them. For illustration, successful exploitation of an asset node *app*, specifically the Sungrow iSolarCloud mobile/web application, directly influences three vulnerability nodes: $v1$, $v2$, and $v3$. Using Equation 17, this asset node's structural impact score was calculated as follows:

$$S(app) = \frac{3}{30} = 0.1 \quad (19)$$

D. POSTERIOR PROBABILITY CALCULATIONS

Once the exposure probabilities and impact-related attributes for vulnerability, asset and hazard nodes are calculated, the posterior probabilities of successful attack and of severe impact to the CPS, given the evidence of a vulnerability node being exploited, for example, can be derived using conditional probability tables and variable elimination [30]. We note that the posterior probability of severe impact, denoted $P(I)$ below, incorporates a combination of severity-grounded (Equation 16) and structural (Equation 17) inputs. Where the attack path traverses an asset or hazard node, $P(I)$ incorporates the structural impact score discussed in Section III-C.

1) RUNNING EXAMPLE

For the running example, the joint conditional probabilities for exposure and impact associated with the attacker's goal are shown in Table 4. These values were derived from Bayesian inference computations based on estimates, posterior parameters and updated evidence from the risk model.

TABLE 4. Joint conditional probability Table for exposure and impact of H8_Power_Outage (State (0): Successful attack).

State	$P(E)$	$P(I)$
(0)	0.4706	0.9153
(1)	0.5294	0.0847

The results show a posterior likelihood of successful attack (exposure) of $P(E) = 0.4706$, and a posterior probability of severe CPS impact given that the attack succeeds of $P(I|E) = 0.9153$ (denoted $P(I)$ for brevity throughout). The product of these two probabilities yields a composite risk score of

$R = P(E) \times P(I) = 43.07\%$, indicating a moderate risk of CPS disruption in this running example.

E. MULTI-OBJECTIVE OPTIMISATION

Our framework employs multi-objective optimisation to assess and weigh trade-offs between *countermeasure portfolios*, *failure probabilities* and *impact ratings* to inform consequence-driven and risk-informed decision support in CPSs.

1) COUNTERMEASURE PORTFOLIOS

Countermeasure portfolios are instantiated as tuples of *Probability of Mitigation* attributes, embedded within each vulnerability node in the BAG and BIG models. Each portfolio is defined as an ordered tuple

$$\mathbf{M} = (P(M_1), P(M_2), \dots, P(M_n))$$

comprising the mitigation probabilities $P(M_i)$ associated with each vulnerability V_i ($i = 1, 2, \dots, n$) in the BAG model. A higher mitigation probability implies a lower likelihood of successful exploitation at the corresponding node. The ordering of nodes within these tuples reflects the relative effectiveness of mitigation strategies, thereby guiding prioritisation under operational constraints.

2) FAILURE PROBABILITIES

The first author's professional experience suggests that asset failure probabilities can be influenced by mitigation-induced risks. For instance, the application of faulty or unstable security patches to a CPS asset may introduce unintended consequences, including asset failure. This complexity is exacerbated when an asset is linked to multiple vulnerabilities, each associated with distinct mitigation-related risks. In our framework, each countermeasure is associated with a risk adjustment function that governs its net contribution to asset-level failure. Accordingly, the failure probability of a CPS asset is defined as a bounded, risk-adjusted function of the mitigations applied across its associated vulnerabilities:

$$P(F_a | \mathbf{M}) = \min \left(1.0, \frac{\sum_{i \in \mathcal{V}_a} P(\text{Fail}_{\text{mit}}^i)}{|\mathcal{V}_a|} \right) \quad (20)$$

where:

- $P(F_a | \mathbf{M})$ is the probability of failure for CPS asset a given the countermeasure portfolio $\mathbf{M}$;
- $\mathcal{V}_a$ is the set of vulnerabilities associated with asset a ;
- $P(\text{Fail}_{\text{mit}}^i)$ is the probability that mitigation applied to vulnerability i causes unintended adverse consequences that contribute to asset failure;
- The min function ensures the total failure probability remains within the interval $[0, 1]$.

In practice, failure probabilities specific to each vulnerability mitigation should be corroborated with field data, such as user- or vendor-reported issues with deployed mitigations (e.g., software patches for the corresponding vulnerabilities). In the absence of such data for this study, a common,

neutral value of $P(\text{Fail}_{\text{mit}}) = 0.5$ was adopted for illustrative purposes.

3) IMPACT RATINGS

Another important element in the framework is the *Impact Rating* attribute, which is embedded in the derivation of countermeasure portfolios. By acting as a modifier for mitigation probabilities, the impact rating tailors mitigation strategies to address the multifaceted consequences of successful attacks across safety, operational, financial and informational domains. It is computed by adapting the formulation proposed by Amro et al. [31]:

$$\text{Impact Rating} = \frac{\sum_{j \in \{S, F, I, O, St\}} (\text{Factor}_j \cdot \text{Criticality}_j)}{\sum_{j \in \{S, F, I, O, St\}} \text{Factor}_j} \quad (21)$$

where:

- S: safety impact — refers to potential harm to human life or physical injury resulting from a CPS failure or security breach.
- F: financial impact — quantifies monetary losses due to CPS equipment damage, service downtime or disrupted business operations.
- I: informational impact — relates to the compromise, loss or exposure of sensitive data and system configurations.
- O: operational impact — reflects the degree to which core CPS functions or processes are degraded or interrupted.
- St: staging impact — indicates the ability to enable further attacks or facilitate persistence, privilege escalation or lateral movement.
- Factor_j : the relative weight assigned to impact type j .
- Criticality_j : the criticality level associated with impact type j .

The optimisation process begins by randomly generating countermeasure portfolios, denoted as

$$\mathbf{M}^{(j)} \quad (j = 1, 2, \dots, n)$$

Each portfolio's mitigation values are encoded into the BN graph and used to infer the posterior probabilities of both attack success and severe impact on the CPS, via Bayesian inference algorithms. These probabilistic outcomes are treated as parameters within a multi-objective search space. Pareto-optimal portfolios are then identified using the Optuna library [32], balancing the competing objectives of minimising the likelihood of attack success, and at the same time, minimising the probability of severe impact and maximising system availability. The resulting Pareto fronts form the foundation of our proposed decision support mechanism.

4) SYSTEM AVAILABILITY

System availability is the third optimisation objective alongside minimising the likelihoods of attack success and severe

impact. We define availability under a candidate countermeasure portfolio $\mathbf{M}$ as the Impact-Rating-weighted complement of asset failure probability, using the per-component Impact Rating already computed via Equation 21 as the criticality weight for each asset's mitigation-adjusted failure probability from Equation 20:

$$\text{Availability} = 1 - \frac{\sum_{a \in \text{Assets}} (\text{Impact Rating}_a \cdot P(F_a | \mathbf{M}))}{\sum_{a \in \text{Assets}} \text{Impact Rating}_a} \quad (22)$$

where $P(F_a | \mathbf{M})$ is the failure probability of CPS asset a under portfolio $\mathbf{M}$ and Impact Rating_a is the corresponding component's impact rating. Weighting by Impact Rating ensures that the availability objective penalises the failure of operationally-critical assets more heavily than that of lower-criticality assets, consistent with the treatment of impact severity elsewhere in the framework. By construction, this formulation is bounded in $[0, 1]$, since $P(F_a | \mathbf{M})$ is itself bounded in $[0, 1]$ and the weights form a normalised average.

5) RUNNING EXAMPLE

In our running example, Equation 20 was used to calculate the risk-adjusted failure probabilities of CPS assets such as the WiNet-S communication dongle, which are connected to multiple vulnerability nodes, each associated with distinct mitigation-related risks.

TABLE 5. Impact ratings for solar PV inverter components.

Component	F_S	C_S	F_F	C_F	F_I	C_I	F_O	C_O	F_{St}	C_{St}	Impact Rating
Mobile/Web App	1	0	0.25	0	0.25	0.5	0.75	0	0.5	0.25	0.0909
WiNet Web	1	0	0.25	0	0.25	0.5	0.75	0	0.5	0.25	0.0909
MQTT Broker	1	0	0.25	0	0.25	0.5	0.75	0.5	0.5	0.5	0.2727
WiNet-S Dongle	1	0	0.25	0	0.25	0.5	0.75	0.5	0.5	0.5	0.2727
PV Inverter	1	0	0.25	0.25	0.25	0.75	0.75	0.75	0.5	0.5	0.3864
Power Grid	1	0.5	0.25	0.75	0.25	0	0.75	1	0.5	0.75	0.6591

In addition, Equation 21 was used to calculate impact ratings with specific weights and criticality values corresponding to the CPS context, summarised in Table 5. The impact rating of the solar PV inverter was calculated to be 0.3864, reflecting a maximum safety factor of 1.0, based on the overarching principle that safety must never be compromised, alongside more moderate financial, informational, operational, and staging weightings that scale with each factor's practical consequence. These impact ratings were then multiplied by the corresponding mitigation probabilities to derive the countermeasure portfolio.

Finally, a multi-optimisation study was performed to identify Pareto-optimal countermeasure portfolios. The scatter plot (Figure 3) shows a curved, fairly smooth slope across the likelihood and impact axes, rising as impact increases. This points to a consistent relationship between the two dimensions, wherein higher-impact scenarios tend to coincide with higher availability. The smoothness of the slope suggests the CPS environment has underlying systemic regularities, likely driven by the causal structure captured in the BN graph. Between approximately 0.25 and 0.30 on the *Impact* axis, the plot also flattens into a plateau, indicating

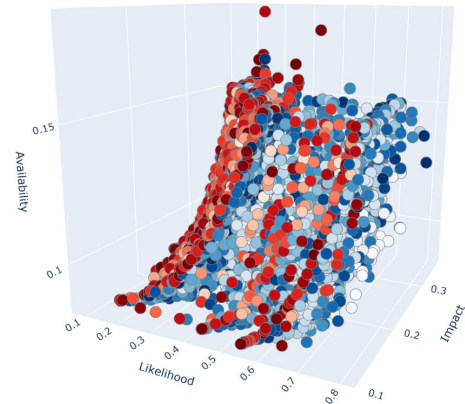


FIGURE 3. Pareto fronts derived over 10,000 multi-objective optimisation trials in the solar PV inverter case study.

that some countermeasure portfolios reduce the likelihood of severe impact without meaningfully improving system availability.

F. FREQUENCY-BASED HEURISTIC ANALYSIS

Lastly, a frequency-based heuristic analysis of Pareto-optimal portfolios is conducted across multiple optimisation runs to rank and identify the vulnerability nodes that most consistently and effectively contributed to high-performing countermeasure configurations. These nodes are strong candidates for prioritisation in mitigation strategies, particularly under operational constraints during incident response.

1) RUNNING EXAMPLE

As shown in Figure 4, vulnerabilities V1, V2, V3, and V15 consistently demonstrate high mitigation effectiveness across portfolio instances. The underlying BN graph structure (Figure 2) corroborates this finding, highlighting these nodes as critical entry points for downstream attack propagation in the CPS. Furthermore, sensitivity analysis across varying AF settings shows that while the Pareto-optimal configuration remains stable, several vulnerability nodes exhibit larger rank variance, suggesting that their relative mitigation effectiveness is dependent on how feasible the attack is.

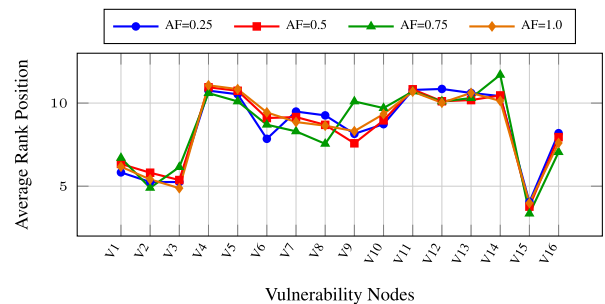


FIGURE 4. Average rank positions of mitigation probabilities across 100 runs of 10,000 optimisation trials, repeated across varying AF settings.

In summary, the key findings of the running example of a solar PV inverter attack are:

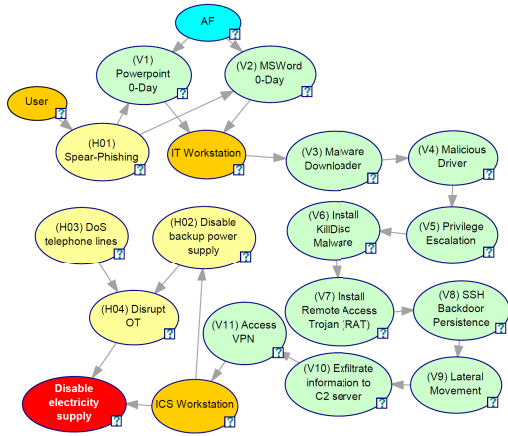


FIGURE 5. Bayesian Network of the Ukrainian power grid (BlackEnergy) attack. A high-resolution version is available in the project's GitHub repository ([11]).

- Optimisation results show systemic regularity, suggesting underlying causal structures within the BN graph.
- A subset of countermeasure portfolios reduce the likelihood of severe impact, yet offer limited gains in system availability.
- Vulnerabilities that demonstrate consistently high mitigation effectiveness reflect their positions as critical entry points in the BN graph.
- While Pareto-optimal countermeasure portfolios remain stable across varying AF settings, individual node ranks display varying degrees of sensitivity to AF selection.

IV. FURTHER EVALUATION ACROSS CPS SCENARIOS

This section evaluates the practical utility and applicability of our proposed framework by applying the methodology to another two representative CPS scenarios beyond the initial solar PV inverter case study. The corresponding results are presented and analysed to highlight key insights, limitations, and implications for real-world deployment.

A. UKRAINIAN POWER GRID (BlackEnergy) ATTACK

Our proposed framework was applied to enable adaptive mitigation of the 2015 Ukrainian power grid attack, which notoriously leveraged the BlackEnergy malware to attack a CPS [33]. Figure 5 presents the corresponding Bayesian Network graph of the attack tree [34] created with the GeNIe Modeler tool [35]. Based on this structure, the BN graph is constructed using available information to define the asset, vulnerability, and hazard nodes, and encoded in AutomationML.

Next, we calculated the exposure and impact probability values using the methodology outlined in Section III. Two of the vulnerability nodes were listed in the National Vulnerability Database (NVD) [36] with CVE identifiers, while the rest were not. Table 6 lists the vulnerability metrics for vulnerability node V2 (CVE-2014-1761: Microsoft Word Remote Code Execution), yielding an exposure probability of $P(E)_{V2,CVE} = 1.0$ (Equation 2) because it was listed in the CISA catalogue of known exploited vulnerabilities.

TABLE 6. Vulnerability metrics for CVE-2014-1761 (retrieved 2026-06-18). Despite age (> 10 years), high CVSS (7.8), LEV (1.0), and KEV listing yield maximum exposure probability (1.0) – indicating the vulnerability is almost certain to be exploited in real-world scenarios.

Scoring System	Score
CVSS v3.1	7.8
EPSS (Latest Score)	0.7773
LEV	1.000 (100%)
KEV	1 (Listed in CISA catalogue)
$P(E)_{V2,CVE}$	1.0

The AF modifier (Equation 7) was then applied. A value of $\phi = 1.0$ was selected to reflect the combination of confirmed exploitation and the contextual conditions documented in the SANS/E-ISAC post-incident analysis [33]. Specifically, the system's security posture was assessed as very weak. The initial attack vector exploited corporate workstations with macro-enabled Office documents, VPN access lacked two-factor authentication, and there was no network segmentation between the IT and OT environments, nor any resident capability to monitor the ICS network for anomalous activity. Compounding this, the adversary demonstrated exceptional capability, comprising a highly skilled, well-resourced team that conducted over six months of undetected reconnaissance before executing a highly synchronised, multistage attack. The resulting probability of a successful attack on the vulnerability node V2 is therefore $P(A)_{V2,CVE} = P(E)_{V2,CVE} \times \phi = 1.0$.

Next, the exposure probabilities of non-CVE vulnerabilities were estimated and calibrated. Taking the example of one such vulnerability node V3, which represents a malware downloader, the CVSS-proxy vector was approximated as: CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H.

This CVSS vector characterises a local attack scenario, interpreted per the metric definitions in Section III-B, and reflects high confidentiality, integrity, and availability loss should the vulnerability be exploited. Based on the CVSS vector, the fallback exposure probability estimate was derived as $P(E)_{V3,CVSS} = 0.306$.

We calibrated this estimate using Equation 5, arriving at a likelihood variance of $\sigma_{CVSS}^2 = 0.0025$ (standard deviation 0.05), reflecting high confidence in the fallback estimate for illustrative purposes. For the prior distribution, we adopted a toy mean of $\mu_0 = 0.3$, assumed as an empirical mean for similar vulnerabilities, together with a variance of $\sigma_0^2 = 0.0025$ (standard deviation 0.05). Using the Bayesian latent variable formulation (Equation 5), the posterior distribution is thus:

$$\mu_{\text{post}} = \frac{(0.3/0.0025) + (0.306/0.0025)}{(1/0.0025) + (1/0.0025)} \approx \mathbf{0.303} \quad (23)$$

$$\sigma_{\text{post}}^2 = \left(\frac{1}{0.0025} + \frac{1}{0.0025} \right)^{-1} = \mathbf{0.00125} \quad (24)$$

The posterior distribution of the shared latent exposure probability $P(E)_{V3,CVSS}^*$ is therefore given by $P(E)_{V3,CVSS}^* \sim \mathcal{N}(0.303, 0.00125)$. The low variance indicates that the

posterior calibrated estimate can be used with relatively high confidence within the Bayesian network. Next, we performed a sensitivity analysis over two prior distributions ($\mu_0 = 0.3$, $\mu_0 = 0.5$ – reflecting a prior that the proxy estimate of 0.306 disagrees with). Comparing the results in Table 7, the $\mu_0 = 0.5$ prior distribution shows a markedly large change from the baseline (21.24%) when σ_{CVSS} is increased to 0.20. By contrast, the $\mu_0 = 0.3$ distribution is relatively stable, showing a maximum deviation of only 0.87%. We discuss this further in Section V.

TABLE 7. Sensitivity analysis results (BlackEnergy), showing the effect of varying the CVSS-proxy standard deviation σ_{CVSS} on the calibrated posterior estimate across two priors.

Scenario	μ_0	σ_{CVSS}	σ_{CVSS}^2	μ_{post}	σ_{post}^2	Δ (%)
BlackEnergy ($\mu_0 = 0.3$)	0.3	0.05	0.0025	0.3030	0.00125	Baseline
	0.3	0.10	0.0100	0.3012	0.00200	-0.59%
	0.3	0.15	0.0225	0.3006	0.00225	-0.79%
	0.3	0.20	0.0400	0.3004	0.00235	-0.87%
BlackEnergy ($\mu_0 = 0.5$)	0.5	0.05	0.0025	0.4030	0.00125	Baseline
	0.5	0.10	0.0100	0.4612	0.00200	14.44%
	0.5	0.15	0.0225	0.4806	0.00225	19.26%
	0.5	0.20	0.0400	0.4886	0.00235	21.24%

The AF modifier was similarly applied with $\phi = 1.0$. The resulting probability of a successful attack on the vulnerability node V3 is therefore $P(A)_{V3,CVSS} = P(E)_{V3,CVSS}^* \times \phi = 0.3004$.

TABLE 8. Joint conditional exposure and impact probabilities (BlackEnergy).

State	$P(E)$	$P(I)$
(0)	0.1640	0.2393
(1)	0.8360	0.7607

Table 8 lists the conditional probabilities for exposure and impact associated with the attacker’s goal, derived using Bayesian inference via variable elimination. The results show a posterior likelihood of successful attack of $P(E) = 0.1640$, and a corresponding posterior probability of severe impact on the CPS of $P(I) = 0.2393$. The composite risk score is computed as $R = P(E) \times P(I) = 3.92\%$ in the BlackEnergy attack. As with the running example, $P(I)$ here incorporates a combination of severity-grounded and structural inputs. Whilst this score may appear low given that this scenario is grounded in a confirmed real-world incident, it does not contradict the historical record. Rather, it reflects the framework’s modelling of attack success likelihood under the specified security posture, wherein propagation of posterior probabilities across the multi-stage attack chain suppresses the marginal exposure probability at the attacker goal node.

We recommend that practitioners do not interpret this composite risk score in isolation for incident-prioritisation purposes, but to do so alongside complementary metrics instead. A fuller discussion of this interpretive risk, and its implications for deep, multi-stage attack chains more generally, is provided in Section V.

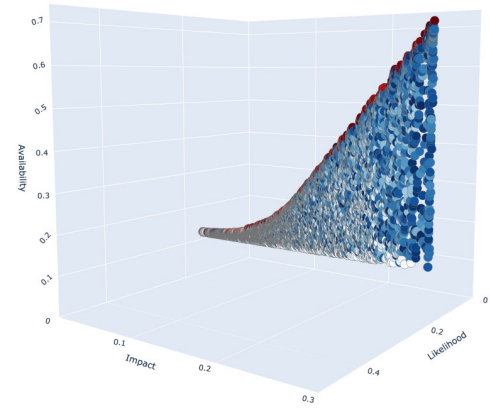


FIGURE 6. Pareto fronts derived over 10,000 optimisation trials in the BlackEnergy case study.

TABLE 9. Top-performing countermeasure portfolio from the BlackEnergy case study.

Metric	Value
Trial ID	9683
Countermeasure portfolio	V1:0.9901, V2:0.9855, V3:0.9777, V4:0.9821, V5:0.9954, V6:0.9892, V7:0.9824, V8:0.9903, V9:0.9713, V10:0.9722, V11:0.9772
Likelihood of successful attack	0.1486
Probability of severe impact	0.2899
Availability	0.6766

Next, we performed optimisation studies to search for Pareto-optimal countermeasure portfolios to support decision-making in mitigating the BlackEnergy attack. Figure 6 reveals an increasingly linear relationship between impact probability and system availability at higher impact probability levels. Additionally, the Pareto fronts appear clustered near a similar value along the attack success likelihood axis, suggesting limited variation in attack success likelihood across trials.

Analysis of the top-performing countermeasure portfolio presented in Table 9 highlights a clear trade-off between exposure, impact, and system availability. The model prescribes near maximal intervention across all identified vulnerabilities, with mitigation parameters approaching 1.0. Despite these intensive efforts, the probability of severe impact remains moderate at 0.2899. This suggests that in the context of the BlackEnergy attack, aggressive mitigation successfully bolsters system availability but fails to fully suppress the residual risk of severe impact on the CPS – evidence that structural interdependencies within CPSs can sustain severe impact even when individual node exposure is significantly reduced.

Lastly, we performed a frequency-based heuristic analysis of Pareto-optimal portfolios across multiple optimisation runs to identify countermeasure recommendations for mitigating the BlackEnergy attack. As shown in Figure 7, vulnerabilities V3–V8 and V10 exhibit comparable bar heights, indicating

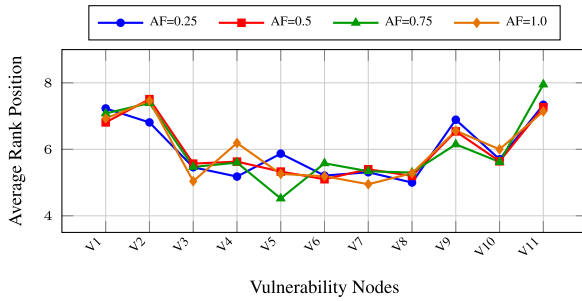


FIGURE 7. Average rank positions of mitigation probabilities across 100 runs of 10,000 optimisation trials, repeated across varying AF settings.

that effective mitigation requires a distributed strategy across multiple vulnerability nodes concurrently. Although this approach demands greater resources, partial implementation yields proportional losses – implementing only two of these seven top-ranked mitigations (e.g., V3 and V4) achieves only $\approx 28.57\%$ (2/7) of the full portfolio’s effectiveness, leaving critical attack paths unaddressed. Sensitivity analysis further demonstrates that while Pareto-optimal portfolios remain relatively stable, individual nodes show noticeably larger rank variance across varying AF settings compared to the solar PV inverter case study (Figure 4). This suggests that certain vulnerability nodes in this scenario are more sensitive to attack feasibility, and the recommended mitigation priorities for these nodes can be expected to change across varying AF settings.

In summary, the key findings from the framework’s application to the Ukrainian power grid attack are:

- Increasingly linear relationship between impact probability and system availability at higher impact probability levels.
- Pareto fronts appear clustered near a similar value along the attack success likelihood axis, suggesting limited variation in attack success likelihood across optimisation trials.
- Aggressive mitigation improves availability, but does not fully suppress the residual risk of severe impact on the CPS.
- Mitigation must adopt a distributed strategy across multiple vulnerability nodes concurrently.

B. RAILWAY CBTC SYSTEM ATTACK

Next, we shifted our focus to a cyber-physical attack scenario involving a railway CBTC system. To construct a plausible threat model, we drew upon the first author’s years of expertise and domain-specific knowledge of railway CBTC systems, complemented by insights from literature that discuss railway-specific risk assessment methods and considerations [37]. Synthesising these insights, we formulated a hypothetical cyber-physical attack path that targets CBTC assets through a chain of associated cyber-physical vulnerabilities. These relationships were instantiated within a Bayesian Network model, as illustrated in Figure 8.



FIGURE 8. Bayesian network of a hypothetical cyber-physical attack on a railway CBTC system. A high-resolution version is available in the project’s GitHub repository ([11]).

As the entire attack scenario was hypothetical, the vulnerabilities in this case study were not linked to any actual CBTC-related CVE entries. To address this limitation, CVSS 3.1 vectors were constructed by referencing *analogous vulnerabilities* catalogued in the NVD, which bore semantic and structural alignment with the hypothetical vulnerabilities. Initial exposure probability estimates were heuristically derived using Equation 3, and subsequently calibrated using the Bayesian latent variable approach outlined in Equation 5, taking the assumption of low-confidence estimates.

This approach, however, references CVEs (Table 10) that originate from general-purpose ICS, IT, or IoT contexts, and their CVSS vectors may not reflect the exploitability of CBTC-specific equipment given its physical isolation, proprietary protocols, and safety-certified architecture. We treat this cross-domain mapping as a necessary but imperfect substitute in the absence of publicly disclosed CBTC vulnerabilities, and practitioners should interpret the resulting estimates as approximated metrics rather than as validated CBTC risk figures. Validating against domain expert assessments and published railway-specific risk studies is left to future work.

The AF modifier (Equation 7) was also applied to incorporate attack feasibility in the computation. A value of $\phi = 0.5$ was selected to reflect the contextual conditions typical of an “air-gapped” (i.e., physically isolated) CBTC environment as shown in Figure 8, with the system’s security posture assessed as moderate. Cybersecurity practices within this air-gapped CBTC environment were assumed to be moderately controlled but imperfect: removable media used by contractors during routine maintenance were only partially scanned, and internal network segmentation between the safety-critical zone-controller network and the broader maintenance subnet was incomplete, lacking lateral movement monitoring. The adversary is characterised as a competent,

moderately resourced insider threat or a persistent team using compromised supply-chain media to execute a multi-stage attack starting at the workstation level. The resulting probability of a successful attack on a vulnerability node is therefore calculated as $P(A) = P(E) \times 0.5$.

As the CVSS-based vectors in this scenario were derived entirely from analogous vulnerability references, we performed a comparative analysis against corresponding EPSS-based scores reflecting empirical “in-the-wild” attack probabilities. Specifically, we aimed to assess whether the model’s output (posterior probabilities) would differ materially between the two scoring systems. For instance, in the case of V1 (CVE-2020-7544), the corresponding CVSS vector (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H) yielded $P(E)_{\text{vuln, CVSS}} = 0.55 \times 0.77 \times 0.62 \times 0.85 = 0.2232$, greatly exceeding the corresponding EPSS score of 0.00309.

TABLE 10. Comparison of CVSS- and EPSS-based exposure probabilities for each vulnerability.

ID	CVE	Threat Category	CVSS 3.1	EPSS
V1	CVE-2020-7544	Elevation of Privilege	0.2232	0.00309
V2	CVE-2023-36857	MiTM Network Replay	0.4984	0.00309
V3	CVE-2024-23814	Network Flooding	0.4984	0.00574
V4	CVE-2023-0972	Over-The-Air Sniffing	0.4984	0.00347
V5	CVE-2026-22917	Jamming	0.4984	0.00509
V6	CVE-2022-32747	Message Spoofing	0.4984	0.00311
V7	CVE-2019-10936	Message Dropping	0.4865	0.02065
V8	CVE-2023-36857	MiTM Network Replay	0.4984	0.00309

Table 10 confirms that this pattern holds across all eight vulnerabilities in this scenario, with CVSS-based exposure probabilities consistently exceeding their EPSS counterparts. This suggests that, in this scenario, CVSS over-estimates vulnerability exposure relative to EPSS, which instead reflects the empirical likelihood of near-term exploitation as observed in the wild.

TABLE 11. Comparison of CVSS- and EPSS-based joint conditional exposure and impact probabilities (Railway CBTC).

State	CVSS-Based		EPSS-Based	
	$P(E)$	$P(I)$	$P(E)$	$P(I)$
(0)	0.1574	1.0000	0.1574	1.0000
(1)	0.8426	0.0000	0.8426	0.0000

As shown in Table 11, the joint conditional probability distributions for exposure ($P(E)$) and impact ($P(I)$) are identical under both the CVSS- and EPSS-based configurations. This indicates that, in this scenario, the differences between CVSS- and EPSS-based exposure probabilities do not translate into materially different downstream risk estimates. This convergence further suggests that the BN’s graph structure, rather than the choice of scoring system, is the dominant driver of the posterior outcome. Because the attack path depends on a combination of several upstream conditions, including the individual exposure probabilities of each contributing node, the joint conditional probability is comparatively insensitive to moderate shifts in any single node’s exposure probability.

Secondly, the analysis highlights a significant vulnerability within the railway CBTC architecture. While the likelihood of attack success is relatively low ($P(E) = 0.1574$), the propagated impact score reaches its ceiling ($P(I) = 1.0$), reflecting that the attack path terminates directly at the highest-connectivity hazard node in the graph. Consequently, these results suggest that preventive strategies should be prioritised to reduce the probability of entry, as the current system configuration offers no structural buffering once the goal is achieved.

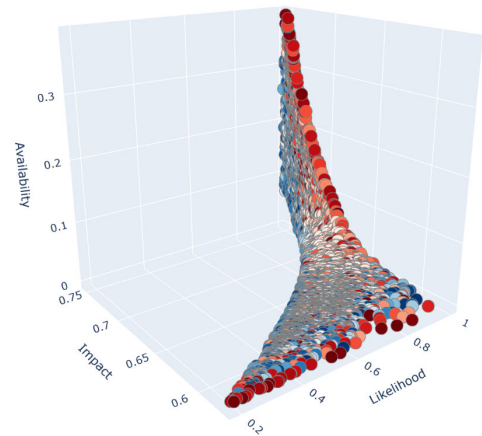


FIGURE 9. Pareto fronts derived over 10,000 multi-objective optimisation trials in the railway CBTC case study.

Next, we conducted optimisation experiments, separately using calibrated CVSS-based priors and EPSS-based priors to evaluate differences in outcomes. In both cases, the derivation of the Pareto fronts (Figure 9) illustrates a trade-off between exposure, impact, and availability. The results show a consistent relationship in which the likelihood of severe impact remains elevated across most levels of attack success likelihood. Dense solution clusters are observed near $Likelihood \approx 0.2 - 0.4$, with a sparser tail of solutions extending toward $Likelihood \approx 1$. Across these Pareto fronts, impact remains consistently high, while availability is generally low, rising only as attack success likelihood approaches its upper bound. This suggests that the optimisation process prioritises minimising attack success likelihood over reducing impact severity, with availability improving only as a secondary effect at high attack success likelihood.

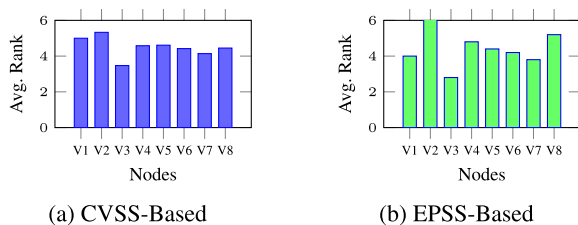
The top-performing countermeasure portfolios are presented in Table 12. Both CVSS- and EPSS-based solutions reflect a broad system-wide defence strategy in the scenario of a railway CBTC attack, with near-maximal mitigation across all variables.

Lastly, we analysed Pareto-optimal portfolios obtained from repeated optimisation runs using both calibrated CVSS- and EPSS-based priors, applying a frequency-based ranking to identify which vulnerability nodes were most consistently selected for Pareto-optimal countermeasure portfolios. There were visible differences between results derived from calibrated CVSS- and EPSS-based priors respectively.

TABLE 12. Comparison of top-performing countermeasure portfolios from the railway CBTC case study using calibrated CVSS-based and EPSS-based priors.

Metric	CVSS-based (Trial 8361)	EPSS-based (Trial 9234)
Countermeasure portfolio	V1:0.9986, V2:0.9883, V3:0.9788, V4:0.9994, V5:0.9929, V6:0.9961, V7:0.9579, V8:0.9914	V1:0.9759, V2:0.9778, V3:0.9792, V4:0.9835, V5:0.9942, V6:0.9873, V7:0.9862, V8:0.9532
Probability of severe impact	0.7581	0.7559
Availability	0.4694	0.4462
Total execution time	0h 4m 31s	0h 4m 23s

As illustrated in Figure 10, the calibrated CVSS-based distribution exhibits a largely uniform pattern, with V3 exhibiting the strongest mitigation effect. In contrast, the EPSS-based distribution is more varied, with V2 exhibiting visibly lower mitigation effects relative to other nodes. This marked difference in the CVSS- and EPSS-based distributions may be due to the more heterogeneous empirical attack probabilities that are incorporated in the EPSS-based priors.

**FIGURE 10. Comparison of average mitigation rank positions across 100 optimisation runs. Lower values indicate higher mitigative effectiveness.**

In summary, the key findings from the framework's application to the railway CBTC system attack are:

- No marked differences between conditional probability tables based on CVSS- and EPSS-based priors.
- Optimisation results prioritise attack prevention over reducing impact severity, with availability improving only as a secondary effect at high attack success likelihood.
- Countermeasure portfolios show near-maximal mitigation across all vulnerabilities, reflecting a system-wide defence approach.
- Frequency analysis shows uniform emphasis in countermeasure portfolios derived from calibrated CVSS-based priors, while portfolios derived from EPSS-based priors indicate more targeted mitigation strategies.

C. TRADE-OFFS AND PRACTITIONER GUIDANCE

In interpreting the results of our three case studies, scenario-specific behaviours should be distinguished from properties of the framework itself. Patterns such as the shapes of Pareto fronts, the prominence of specific vulnerabilities, or clustering effects in the BlackEnergy and CBTC experiments stem from the particular architectures, threat models, and

parameter settings of those scenarios. In contrast, the ability to generate Pareto-optimal countermeasure portfolios, quantify trade-offs between exposure, impact, and availability, and rank mitigation options via frequency-based heuristics are general characteristics of our proposed method that should extend to a broad range of CPS deployments.

These findings provide practical guidance for CPS practitioners regarding the navigation of security trade-offs. The results indicate that complementary vulnerability scoring systems such as CVSS, EPSS, LEV, and KEV can be used flexibly even when vulnerabilities lack CVE identifiers. Specifically, the integration of LEV and KEV scores ensures that confirmed exploitation evidence and local environmental factors take precedence in the prioritisation process. This multidimensional approach, supported by frequency analysis for the comparative evaluation of results, enables more targeted mitigation strategies under operational constraints.

A central insight from our evaluation is that incident mitigation in CPSs inherently involves a three-way trade-off between exposure, impact, and system availability. Across all case studies, the optimisation results reveal regions where reducing the likelihood of successful attack or severe impact begins to incur disproportionately high availability costs, as well as regions where additional mitigation yields diminishing returns in risk reduction. In practice, operators must therefore balance tolerable residual exposure and impact against the need to keep CPS services online, rather than pursuing maximal mitigation in isolation.

V. DISCUSSION AND FUTURE WORK

A. FRAMEWORK APPLICABILITY TO REAL-WORLD ATTACKS

All three case studies, including the solar PV inverter running example in Section III, demonstrate the applicability and utility of our proposed framework in supporting adaptive decision-making needs for real-world attacks. As new information becomes available, elements such as CPS assets, probabilistic estimates of attack success likelihood, impact severity, system availability, and candidate countermeasure profiles, comprising mitigation probabilities, are continuously updated via a feedback loop driven by security monitoring and computationally efficient multi-objective optimisation.

From a deployment perspective, the framework presupposes access to architectural knowledge, vulnerability metadata such as CVEs, and attack telemetry to update evidence in the BN graph. It is designed to integrate as an analytical back-end that can be invoked from existing Security Operations Centre (SOC) workflows. In particular, the framework can serve as a complementary decision-support service that consumes alerts and configuration data, rather than replacing existing SOC tooling. Our experiments in this work demonstrate that multi-objective optimisation can be parallelised to ensure runtimes compatible with operational time-frames. However, practical deployments will require engineering trade-offs between model granularity,

update frequency, and available compute resources to ensure acceptable overhead in operational settings.

B. PRIOR-DOMINANCE IN BAYESIAN CONFIDENCE CALIBRATION

The choice of priors largely determines the behaviour of our proposed Bayesian confidence calibration technique detailed in Section III-B. From Equation 5, we observe that the posterior mean μ_{post} is a precision-weighted average of the prior mean μ_0 and the CVSS-proxy estimate $P(E)_{\text{vuln, CVSS}}$, represented as follows:

$$\mu_{\text{post}} = w_0 \mu_0 + (1 - w_0) P(E)_{\text{vuln, CVSS}} \quad (25)$$

$$w_0 = \frac{1/\sigma_0^2}{1/\sigma_0^2 + 1/\sigma_{\text{CVSS}}^2} \quad (26)$$

where $w_0 \in (0, 1)$ is the precision-weighted contribution of the prior, determined by the ratio of the prior variance σ_0^2 to the CVSS-proxy variance σ_{CVSS}^2 , not their absolute values.

With a prior $\sigma_0^2 = 0.0025$ against a baseline $\sigma_{\text{CVSS}}^2 = 0.04$ (reflecting a neutral Gaussian distribution and a low-confidence CVSS estimate, respectively), the prior carries the bulk of the posterior weight: $w_0 \approx 0.94$. Consequently, μ_{post} remains close to μ_0 across all tested configurations (Tables 3 and 7).

The prior's dominance is intentional, not a structural inability to respond to proxy evidence. Because CVSS-proxy estimates for undocumented vulnerabilities are prone to assessor bias [24], we deliberately set a tight prior standard deviation ($\sigma_0 = 0.05$) so that a single noisy CVSS-proxy estimate cannot dominate the posterior when confidence in that estimate is low (e.g., $\sigma_{\text{CVSS}} = 0.20$). However, this restraint is not absolute, as illustrated in the BlackEnergy scenario (Section IV-A). Here, a high-confidence proxy of $P(E)_{\text{vuln, CVSS}} = 0.306$ that disagrees with the prior ($\mu_0 = 0.5$) still produces a material shift in μ_{post} , demonstrating genuine responsiveness to strong evidence.

The σ_0 value can therefore be regarded as a supporting component for the risk assessment. Setting σ_0 empirically, from the observed spread of proxy estimates across comparable vulnerabilities, is left as a direction for future work.

C. REPEATABILITY OF OPTIMISATION OUTCOMES

An important consideration arising from our research concerns the repeatability of outcomes, such as countermeasure portfolios, produced by multi-objective optimisation trials in response to identical model configurations and threat information. This directly relates to the stability and variance of Pareto fronts across repeated optimisation runs. To evaluate this, we pose the question: *What configuration of trial count is sufficient to ensure that the resulting Pareto front remains relatively consistent across independent multi-objective optimisation runs?*

To address this research question, we evaluated the nearness and clustering behaviour of Pareto fronts generated

TABLE 13. Comparison of KDE-derived density metrics for Pareto-optimal solutions across trial configurations (100 runs each).

Metric	100 trials	1,000 trials	5,000 trials	10,000 trials
Average KDE	601.17	543.70	359.65	395.99
Minimum density	136.64	51.13	31.01	45.91
Maximum density	1130.66	1041.85	698.14	887.52
Density variance	62,435.93	84,427.79	36,824.83	56,210.58
Density entropy	4.51	4.44	4.43	4.40

from 100, 1000, 5000, and 10,000 trials, each repeated over 100 optimisation runs. Comparison of the Pareto fronts across experimental configurations reveals that lower trial counts (e.g. 100) result in considerable dispersion and variability across runs, whereas higher trial counts (e.g. 5000 and 10,000) yield denser, more structurally consistent front distributions across objective space.

Kernel Density Estimation (KDE) [38] was employed, following unimodality validation across attack success likelihood, impact probability, and availability, to quantify and compare cluster densities (Table 13). The results confirm that 5,000 trials suffice to produce consistent, structurally reliable Pareto fronts across independent optimisation runs. However, applications requiring finer resolution or density differentiation (e.g., countermeasure ranking or adaptive planning) may benefit from a 10,000-trial configuration, albeit with higher execution time.

D. CONCURRENCY AND COMPUTATIONAL EFFICIENCY

The optimisation experiments conducted in this research underscore the critical role of concurrency in enhancing computational efficiency and responsiveness for multi-objective decision-making in CPSs. Using the Python concurrent.futures module, we achieved substantial reductions in cumulative optimisation time (Table 14).

TABLE 14. Comparison of execution times for 3 runs of 10,000 trials each.

Configuration	Optuna	Optuna + concurrent.futures
Total execution time	15 mins 3 secs	5 mins 10 secs

E. THREATS TO VALIDITY

A limitation of this evaluation is the absence of ground-truth benchmarks: none of the three case studies are scored against an independently verified “correct” countermeasure portfolio. This is difficult to avoid in practice, since documented remediation sequences for real incidents are rarely published in sufficient detail, red-team outcomes are typically held privately, and the CBTC scenario is hypothetical by construction. We therefore present the three case studies as evidence that the framework produces Pareto-optimal, operationally-interpretable portfolios across diverse CPS domains, not as evidence that those portfolios are optimal in an absolute sense. Establishing the latter would require proprietary incident response data or a dedicated red-team evaluation, which we leave to subsequent work.

F. PRACTICAL IMPLICATIONS

It is important to distinguish our proposed framework from existing Operational Technology (OT) security platforms such as Claroty [8], Dragos [9], and others. Whereas these platforms are designed for incident detection and response, our proposed framework is more appropriately positioned as an *adaptive decision-support tool* for CPS practitioners, particularly in situations where evidence is incomplete and system states are evolving. In this respect, our proposed framework complements, rather than replaces, existing OT security platforms.

Secondly, we emphasise that the three case studies in this work are intended to demonstrate the applicability and mechanics of our proposed framework, rather than to provide a comparative or ground-truth evaluation against alternative decision-support approaches. The BlackEnergy and solar PV inverter scenarios are grounded in real, CVE-linked vulnerabilities and publicly documented incident reports, but the railway CBTC scenario is, by necessity, fully hypothetical, as no equivalent public incident or CVE record exists for this CPS. The conjunctive propagation of posterior probabilities across BlackEnergy's multi-stage attack chain yields a low composite risk score despite being the only scenario grounded in a confirmed real-world blackout. This reflects the framework's modelling of attack success likelihood under a specified security posture rather than historical impact severity, and practitioners should be aware that deep, multi-stage attack paths may systematically produce lower marginal exposure probabilities than shallower, opportunistic attack trees.

We clarify that this does not indicate the framework is miscalibrated: recomputing the risk score R under a weaker security posture (e.g., ϕ approaching 1.0) yields proportionally higher scores, confirming the model responds correctly to its inputs. Rather, the result highlights a limitation of using a single composite score for incident prioritisation in deep attack chains. We recommend that practitioners interpret scores with $P(I)$ as a complementary metric: in the BlackEnergy scenario, $P(I) = 0.2393$ (Table 8) signals that a realised attack path carries considerable consequence, information the low composite risk score alone obscures.

G. FUTURE WORK

To further strengthen decision-making capabilities in CPS environments, future work should explore several complementary directions that address the key challenges identified in our research.

First, our research highlighted the promise of frequency-based heuristics as a supplementary analytical layer beyond individual optimisation outcomes. However, their empirical nature prompts a critical question: *To what extent can such heuristically derived recommendations be relied upon in safety-critical CPS environments?* Addressing this question presents a valuable avenue for future work, particularly through comparative evaluation with empirical data. Future

work could also extend optimisation to explicitly account for resilience alongside system availability.

Second, the stability of Pareto fronts across repeated optimisation trials remains central to ensuring decision robustness. Low trial counts were shown to produce high variance in outcomes, which may undermine the trustworthiness of mitigation recommendations. Future investigations should therefore develop convergence diagnostics to establish sufficiency thresholds for trial configurations, and to evaluate optimisation solutions.

Third, each AF modifier value in this paper was elicited from a single analyst per scenario, so we do not yet know how much it would vary across analysts assessing the same evidence. The natural next step is to have two or three analysts independently score AF for the same case study and measure agreement directly, then check whether disagreement at that level changes which countermeasures the framework recommends.

Fourth, the incorporation of hybrid confidence-calibrated exposure probability assessments presents a promising direction for performing vulnerability assessment in practical deployments. Such hybrid approaches are particularly relevant in guiding real-world incident mitigation strategies that must adapt in real time to evolving attacks and dynamic threat intelligence. Furthermore, the approach is inherently extensible, facilitating the integration of diverse vulnerability scoring systems such as CVSS, EPSS, LEV, and KEV to refine the quantification of exposure estimates. Future work could further leverage this multidimensional approach to refine decision support, enabling a more comprehensive and data-informed basis for prioritising countermeasures as new threat intelligence becomes available.

Finally, architectural improvements and mechanisms could be explored to dynamically rebalance the factors employed in impact calculations (as outlined in Section III-C), thereby enabling the generation of countermeasure portfolios that reflect evolving runtime priorities. This may include structural enhancements such as the incorporation of noisy-OR gates to improve agility in assimilating new evidence, and to better support adaptive decision-making.

Collectively, these directions aim to further improve an adaptive decision support framework for mitigating cyber incidents in CPSs.

VI. RELATED WORK

A. PROBABILISTIC MODELLING IN CYBERSECURITY

BN graphs are highly effective in synthesising heterogeneous data for cybersecurity modelling, particularly when historical attack data is sparse [40], [41]. Prior studies [6], [27], [42], [43] underscore their utility in dynamic decision-making. Bhosale et al. [14], [15] further integrated hazard, vulnerability, and asset connectivity into Bayesian Belief Networks (BBNs) using AutomationML for data exchange. However, existing frameworks often overlook the operational trade-offs of security mitigations, such as asset degradation or failure from software patching, and do not account for legacy

TABLE 15. Comparison of optimisation frameworks for CPS incident response.

Framework	Vulnerability/Threat Input	Uncertainty Handling	Optimisation Objective(s)	Adaptability Mechanism	Evaluation
Li et al. [4]	CVSS-derived exploitability, fixed	None – point probabilities treated as ground truth	Single-objective intrusion-response ranking	Reactive to detected intrusion; exposure not revised as evidence accrues	Simulated ICS testbed
Żebrowski et al. [7]	Expert-elicited probabilities	None – static, fixed at model-build time	Pareto-efficient portfolio under fixed budget	Offline BN; no update mechanism	Single case study; no ground truth
Zaman et al. [5]	Disruption-event states (not vulnerability-scoring)	Not explicit	MDP-based response-action selection	Adaptive within MDP state space; smart-building domain, not vulnerability-driven	Smart-building case study
Shimizu & Hashimoto [39]	CVSS + EPSS + KEV, deterministically chained	None – scores combined without reliability calibration	Single-objective vulnerability prioritisation	Static; targets enterprise IT, not CPS constraints	Not evaluated on CPS
Proposed	CVSS + EPSS + LEV + KEV, Bayesian-calibrated	Epistemic uncertainty surfaced as posterior variance metric	Joint attack likelihood, availability (multi-objective)	BN attributes updated from evidence; frequency heuristics re-prioritise across runs	Three CPS case studies (real + hypothetical)

system constraints and operational limitations. Furthermore, a heavy reliance on CVSS v3.1 scores limits adaptability to shifting threat landscapes where probabilistic insights from EPSS [19] are required. Our research addresses these gaps by proposing a consequence-aware, iterative framework that integrates confidence-calibrated exposure estimation within an adaptive decision-support pipeline combining BN-based risk propagation, multi-objective optimisation, and frequency-based heuristic prioritisation.

B. CONSEQUENCE-DRIVEN SECURITY ASSESSMENT

Beyond modelling attack propagation, effective CPS decision-making must account for the consequences of cyber-physical incidents. Kim et al. [12] incorporate a consequence layer within BN graphs to quantify impact propagation in exploited ICSs, detailing functional interdependencies and infrastructure-wide effects. In parallel, Amro et al. [31] propose a consequence-driven framework rooted in Failure Mode, Effects, and Criticality Analysis (FMECA) that aligns well with CPS environments. Although these approaches support iterative assessment, their transformation into adaptive tools hinges on modelling realistic, multi-stage attacks. In contrast to these approaches, our research integrates system-level functional dependencies into BN graphs informed by empirical failure modes, explicitly modelling uncertainty within exposure computations to enable responsive decision-making.

C. DECISION SUPPORT FOR CPS INCIDENTS

Research has explored diverse methodologies for CPS decision-making under uncertainty, including Zaman et al.'s [5] MDP (Markov Decision Process) framework for hazard response and Javorník and Husák [13] mission-centric DSS for resilient IT configuration. Both provide structured resilience assessments but lack specific

focus on the adversarial tactics and non-linear cascading risks inherent in CPS incidents – a gap our BN-based approach addresses by modelling risk propagation that reflects evolving threat scenarios.

D. MULTI-OBJECTIVE OPTIMISATION

Decision-making in CPS incident response must balance cybersecurity, safety, and operational resilience. Rehak et al. [3] introduce a methodology for assessing critical infrastructure resilience by evaluating robustness, recovery, and adaptive capacity. However, their model is essentially static and focused on pre-incident conditions. Li et al. [4] propose a multi-objective optimisation framework for intrusion response in ICSs, prioritising Pareto-optimal strategies, yet it does not account for unknown vulnerabilities or emerging vectors. Similarly, Żebrowski et al. [7] use BN graphs to assess cascading impacts but assume static configurations. While Shimizu and Hashimoto [39] proposed a vulnerability management chaining framework integrating CVSS, EPSS, and KEV metrics, their work is tailored to enterprise IT and lacks the multi-objective weighting necessary to balance the high-availability requirements of CPS environments. Our research addresses these limitations by using a Bayesian confidence calibration technique to model emerging threat uncertainty and implementing an iterative multi-objective optimisation cycle to tailor strategies for CPS incident mitigation. Table 15 summarises how our proposed framework relates to comparable prior approaches discussed above.

E. RAILWAY CBTC SYSTEMS

Several studies have examined the security of railway signalling, with varying emphasis on CBTC technologies. Xu et al. [44] present a simulation platform grounded in real-world CBTC characteristics, while Yu et al. [45] offer

a comprehensive review of the architecture, cybersecurity threats, and protection strategies specific to these systems. In contrast, other research focuses on broader or legacy signalling components. For instance, Schlehuber et al. [46] examine interlocking systems without addressing CBTC explicitly, and Unger et al. [47] survey railway attack scenarios and countermeasure maturity across the sector more generally. Regarding systemic vulnerabilities, research has highlighted the risks inherent in the transition to wireless-based control. Farooq and Soler [48] analyse over-the-air communications in CBTC, identifying interference susceptibility in Wi-Fi-based implementations. Oliveira et al. [49] expand on this by using Failure Mode and Effects Analysis (FMEA) to uncover risks such as message spoofing and Man-in-the-Middle (MitM) attacks that compromise communication integrity. Similarly, Soderi et al. [50] outline wireless attack scenarios with demonstrated impacts on railway safety. These findings directly inform the adversarial modelling applied in our CBTC case study, ensuring the evaluation reflects the unique cyber-physical risks inherent in modern automated rail operations.

VII. CONCLUSION

This paper presented an adaptive decision support framework to help practitioners mitigate cyber-physical incidents in CPS environments – a critical need as CPS integration into essential infrastructure grows alongside a diversifying threat landscape. A key contribution is using BN graphs, enriched with system and vulnerability metadata, to represent complex attack scenarios. Encoded in a DSL, these models enable dynamic updates that support adaptive decision-making as incidents unfold. The framework also employs a hybrid exposure probability estimation technique to handle vulnerability uncertainty, especially in legacy CPS assets with incomplete data. This method integrates complementary vulnerability scores via Bayesian confidence calibration, bounding proxy-score bias to produce uncertainty-aware reporting metrics for supporting practitioners with downstream risk assessment. Incorporating uncertainty inputs directly into the decision-support pipeline remains future work.

The framework introduces a decision-support methodology for countermeasure selection based on multi-objective optimisation and frequency-based heuristic analysis. By evaluating mitigation probabilities within a structured search space, the system generates Pareto-optimal portfolios balancing security, safety, and operational resilience. Frequency-based heuristics across repeated optimisation runs translate complex model outputs into actionable, constraint-aware operational guidance.

Application across three representative scenarios: the 2015 Ukrainian power grid (BlackEnergy) attack, a solar PV inverter system, and a railway signalling network, demonstrates the framework's versatility against multi-path and multi-agent CPS threats. To ensure transparency, reproducibility, and further extension, all models, source code, and reference datasets are publicly available [11].

REFERENCES

- [1] S. Dashevskiy, F. La Spina, and D. Dos Santos. (2025). *SUN: DOWN Destabilizing the Grid via Orchestrated Exploitation of Solar Power Systems*. Accessed: Aug. 27, 2026. [Online]. Available: <https://www.foresecout.com/resources/sun-down-research-report/>
- [2] J. M. Taylor and H. R. Sharif, "Security challenges and methods for protecting critical infrastructure cyber-physical systems," in *Proc. Int. Conf. Sel. Topics Mobile Wireless Netw. (MoWNeT)*, May 2017, pp. 1–6.
- [3] D. Rehak, P. Senovsky, M. Hromada, and T. Lovecek, "Complex approach to assessing resilience of critical infrastructure elements," *Int. J. Crit. Infrastruct. Protection*, vol. 25, pp. 125–138, Jun. 2019.
- [4] X. Li, C. Zhou, Y.-C. Tian, and Y. Qin, "A dynamic decision-making approach for intrusion response in industrial control systems," *IEEE Trans. Ind. Informat.*, vol. 15, no. 5, pp. 2544–2554, May 2019.
- [5] M. Zaman, R. Eini, N. Zohrabi, and S. Abdelwahed, "A decision support system for cyber physical systems under disruptive events: Smart building application," in *Proc. IEEE Int. Smart Cities Conf. (ISC2)*, Sep. 2022, pp. 1–7.
- [6] N. Poolsappasit, R. Dewri, and I. Ray, "Dynamic security risk management using Bayesian attack graphs," *IEEE Trans. Dependable Secure Comput.*, vol. 9, no. 1, pp. 61–74, Jan. 2012.
- [7] P. Żebrowski, A. Couce-Vieira, and A. Mancuso, "A Bayesian framework for the analysis and optimal mitigation of cyber threats to cyber-physical systems," *Risk Anal.*, vol. 42, no. 10, pp. 2275–2290, Oct. 2022.
- [8] Claroty. (2026). *Vulnerability & Risk Management for Industrial Environments*. Accessed: Aug. 27, 2026. [Online]. Available: <https://claroty.com/industrial-cybersecurity/vulnerability-and-risk-management>
- [9] Dragos. (2024). *Enhance Efficiency & Boost Productivity by Integrating Cybersecurity and Operations*. Accessed: Aug. 27, 2026. [Online]. Available: <https://www.dragos.com/blog/integrating-cybersecurity-and-operations>
- [10] M. Fowler, *Domain-Specific Languages*. London, U.K.: Pearson, 2010.
- [11] S. Huang. (2026). *Bayesian and Multi-Objective Decision Support for Real-Time Cyber-Physical Incident Mitigation—Project Repository*. Accessed: Aug. 27, 2026. [Online]. Available: <https://github.com/shaofei Huang/cps-bayesian-optuna-dss>
- [12] A. Kim, J. Oh, K. Kwon, and K. Lee, "Consider the consequences: A risk assessment approach for industrial control systems," *Secur. Commun. Netw.*, vol. 2022, pp. 1–19, Jun. 2022.
- [13] M. Javorník and M. Husák, "Mission-centric decision support in cybersecurity via Bayesian privilege attack graph," *Eng. Rep.*, vol. 4, no. 12, p. 12538, Dec. 2022.
- [14] P. Bhosale, W. Kastner, and T. Sauter, "Integrated safety-security risk assessment for production systems: A use case using Bayesian belief networks," in *Proc. IEEE 21st Int. Conf. Ind. Informat. (INDIN)*, Jul. 2023, pp. 1–6.
- [15] P. Bhosale, W. Kastner, and T. Sauter, "AutomationML meets Bayesian networks: A comprehensive safety-security risk assessment in industrial control systems," *IEEE Open J. Ind. Electron. Soc.*, vol. 5, pp. 823–835, 2024.
- [16] R. Drath, A. Luder, J. Peschke, and L. Hundt, "AutomationML—The glue for seamless automation engineering," in *Proc. IEEE Int. Conf. Emerg. Technol. Factory Automat.*, Sep. 2008, pp. 616–623.
- [17] FIRST. (2015). *Common Vulnerability Scoring System V3.1: Specification Document*. Accessed: Aug. 27, 2026. [Online]. Available: <https://www.first.org/cvss/v3-1/specification-document>
- [18] P. Mell, K. Scarfone, and S. Romanosky, "Common vulnerability scoring system," *IEEE Secur. Privacy Mag.*, vol. 4, no. 6, pp. 85–89, Nov. 2006.
- [19] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," *Digit. Threats: Res. Pract.*, vol. 2, no. 3, pp. 1–17, Sep. 2021.
- [20] CISA. (2026). *Known Exploited Vulnerabilities Catalog*. Accessed: Aug. 27, 2026. [Online]. Available: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [21] P. Mell and J. Spring, "Likely exploited vulnerabilities—A proposed metric for vulnerability exploitation probability," in *Proc. NIST CSWP*, 2025, pp. 1–30.
- [22] R. Dewri, N. Poolsappasit, I. Ray, and D. Whitley, "Optimal security hardening using multi-objective optimization on attack tree models of networks," in *Proc. 14th ACM Conf. Comput. Commun. Secur.*, Oct. 2007, pp. 204–213.

- [23] A. Dabrowski, J. Ullrich, and E. R. Weippl, "Grid shock: Coordinated load-changing attacks on power grids: The non-smart power grid is vulnerable to cyber attacks as well," in *Proc. 33rd Annu. Comput. Secur. Appl. Conf.*, 2017, pp. 303–314.
- [24] J. Wunder, A. Kurtz, C. Eichenmüller, F. Gassmann, and Z. Benenson, "Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities," in *Proc. IEEE Symp. Secur. Privacy (SP)*, May 2024, pp. 1102–1121.
- [25] F. Küppers, J. Kronenberger, J. Schneider, and A. Haselhoff, "Bayesian confidence calibration for epistemic uncertainty modelling," in *Proc. IEEE Intell. Vehicles Symp. (IV)*, Jul. 2021, pp. 466–472.
- [26] B. T. Knapik, A. W. van der Vaart, and J. H. van Zanten, "Bayesian inverse problems with Gaussian priors," *Ann. Statist.*, vol. 39, no. 5, pp. 2626–2657, Oct. 2011.
- [27] P. Xie, J. H. Li, X. Ou, P. Liu, and R. Levy, "Using Bayesian networks for cyber security analysis," in *Proc. IEEE/IFIP Int. Conf. Dependable Syst. Netw. (DSN)*, Jun. 2010, pp. 211–220.
- [28] A. Kumar, M. Saini, D. K. Saini, and N. Badiwal, "Cyber physical systems-reliability modelling: Critical perspective and its impact," *Int. J. Syst. Assurance Eng. Manage.*, vol. 12, no. 6, pp. 1334–1347, Dec. 2021.
- [29] L. Akoglu, H. Tong, and D. Koutra, "Graph based anomaly detection and description: A survey," *Data Mining Knowl. Discovery*, vol. 29, no. 3, pp. 626–688, May 2015.
- [30] N. L. Zhang and D. Poole, "Exploiting causal independence in Bayesian network inference," *J. Artif. Intell. Res.*, vol. 5, pp. 301–328, Dec. 1996.
- [31] A. Amro, V. Gkioulos, and S. Katsikas, "Assessing cyber risk in cyber-physical systems using the ATT&CK framework," *ACM Trans. Privacy Secur.*, vol. 26, no. 2, pp. 1–33, May 2023.
- [32] T. Akiba, S. Sano, T. Yanase, T. Ohta, and M. Koyama, "Optuna: A next-generation hyperparameter optimization framework," in *Proc. 25th ACM SIGKDD Int. Conf. Knowl. Discovery Data Mining*, Jul. 2019, pp. 2623–2631.
- [33] SANS, "Analysis of the cyber attack on the Ukrainian power grid," *Electr. Information Sharing and Analysis Center (E-ISAC)*, vol. 388, nos. 1–29, p. 3, 2016.
- [34] R. Kumar, R. Kela, S. Singh, and R. Trujillo-Rasua, "APT attacks on industrial control systems: A tale of three incidents," *Int. J. Crit. Infrastruct. Protection*, vol. 37, Jul. 2022, Art. no. 100521.
- [35] Decision Systems Laboratory. (2025). *GeNIe Modeler*. Accessed: Aug. 27, 2026. [Online]. Available: <https://www.bayesfusion.com/genie/>
- [36] NIST. (2026). *National Vulnerability Database*. Accessed: Aug. 27, 2026. [Online]. Available: <https://nvd.nist.gov/>
- [37] Y. Benghenane, A. Lounis, and M. Sallak, "Safety-cybersecurity co-assurance in railway cyber-physical systems: A structured review and maturity assessment," *IEEE Access*, vol. 14, pp. 94933–94959, 2026.
- [38] Y.-C. Chen, "A tutorial on kernel density estimation and recent advances," *Biostatistics Epidemiology*, vol. 1, no. 1, pp. 161–187, Jan. 2017.
- [39] N. Shimizu and M. Hashimoto, "Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization," 2025, *arXiv:2506.01220*.
- [40] S. Chockalingam, W. Pieters, A. Teixeira, and P. van Gelder, "Bayesian network models in cyber security: A systematic review," in *Proc. 22nd Nordic Conf. Secure IT Syst. (NordSec)*, Tartu, Estonia. Cham, Switzerland: Springer, 2017, pp. 105–122.
- [41] S. Huang, C. M. Poskitt, and L. K. Shar, "Security modelling for cyber-physical systems: A systematic literature review," *ACM Trans. Cyber-Phys. Syst.*, vol. 10, no. 2, pp. 1–29, Apr. 2026.
- [42] L. Wang, S. Jajodia, A. Singhal, M. Frigault, L. Wang, S. Jajodia, and A. Singhal, "Measuring the overall network security by combining cvss scores based on attack graphs and Bayesian networks," *Netw. Secur. Metrics*, pp. 1–23, Nov. 2017.
- [43] M. Khosravi-Farmad and A. Ghaemi-Bafghi, "Bayesian decision network-based security risk management framework," *J. Netw. Syst. Manage.*, vol. 28, no. 4, pp. 1794–1819, Oct. 2020.
- [44] J. Xu, L. Chen, W. Gao, and M. Zhao, "CBTC simulation platform design and study," *J. Comput. Commun.*, vol. 3, no. 9, pp. 61–67, 2015.
- [45] Z. Yu, H. Wang, and F. Chen, "Security of railway control systems: A survey, research issues and challenges," *High-Speed Railway*, vol. 1, no. 1, pp. 6–17, Mar. 2023.
- [46] C. Schlehuber, M. Heinrich, T. Vateva-Gurova, S. Katzenbeisser, and N. Suri, "A security architecture for railway signalling," in *Proc. 36th Int. Conf. Comput. Saf., Rel., Secur. (SAFECOMP)*, Trento, Italy. Springer, 2017, pp. 320–328.
- [47] S. Unger, M. Heinrich, D. Scheuermann, S. Katzenbeisser, M. Schubert, L. Hagemann, and L. Iffländer, "Securing the future railway system: Technology forecast, security measures, and research demands," *Vehicles*, vol. 5, no. 4, pp. 1254–1274, Sep. 2023.
- [48] J. Farooq and J. Soler, "Radio communication for communications-based train control (CBTC): A tutorial and survey," *IEEE Commun. Surveys Tuts.*, vol. 19, no. 3, pp. 1377–1402, 3rd Quart., 2017.
- [49] J. Oliveira, G. Carvalho, B. Cabral, and J. Bernardino, "Failure mode and effect analysis for cyber-physical systems," *Future Internet*, vol. 12, no. 11, p. 205, Nov. 2020.
- [50] S. Soderi, D. Masti, M. Hämmäläinen, and J. Iinatti, "Cybersecurity considerations for communication based train control," *IEEE Access*, vol. 11, pp. 92312–92321, 2023.



SHAOFEI HUANG (Graduate Student Member, IEEE) received the bachelor's degree in engineering from The University of Tokyo, in 1998, and the master's degree in business administration from the University of Leicester, in 2002. He is currently pursuing the Doctor of Engineering degree with the School of Computing and Information Systems, Singapore Management University (SMU). He is the Group Chief Information Security Officer with SMRT Corporation. His research focuses on security modeling, anomaly detection, and the self-healing capabilities of cyber-physical systems.



CHRISTOPHER M. POSKITT (Member, IEEE) received the Ph.D. degree in computer science from the University of York, in 2014. He is currently an Associate Professor of Computer Science (Education) with Singapore Management University (SMU), where he is part of the Centre for Research on Intelligent Software Engineering. Prior to SMU, he held a postdoctoral research positions with ETH Zürich and SUTD. His research broadly addresses the problem of engineering correct and secure software, especially in the context of cyber-physical systems (e.g. industrial control systems and autonomous vehicles). In addition to software engineering, his research interests include span formal methods, cybersecurity, and computer science education.



LWIN KHIN SHAR (Member, IEEE) received the Ph.D. degree in software engineering from Nanyang Technological University (NTU), Singapore, in 2014. He was a Postdoctoral Research Associate with SnT, University of Luxembourg, Esch-sur-Alzette, Luxembourg, and then a Research Scientist with NTU. He is currently an Associate Professor with the School of Computing and Information Systems, Singapore Management University, Singapore. He is author or co-author of more than 40 research papers published in international journals and conferences/workshops, including top venues (e.g., IEEE TRANSACTIONS ON SOFTWARE ENGINEERING, IEEE TRANSACTIONS ON DEPENDABLE AND SECURE COMPUTING, *Empirical Software Engineering*, International Conference on Software Engineering, Foundations of Software Engineering, and *Automated Software Engineering*). In his research, he often collaborates with industry partners spanning from healthcare and traffic management to government sectors. His research interests include software engineering, security and privacy, and machine learning, while specializing in analysis of web and mobile applications and recently cyber-physical systems for detecting security vulnerabilities, privacy issues, malware, and anomalies.

...